CASE STUDY

The Year 2016 in Intrusions: A Dated Record

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

For most people who lived through it, 2016 is remembered for a hack and a leak: a political party's email, stolen and published in the middle of a presidential campaign. The record behind that memory is larger and stranger. In February an attacker inside Bangladesh Bank's SWIFT system tried to move $951 million out of the bank's account at the Federal Reserve Bank of New York and got away with $81 million [26][29]. Through the year, ransomware reached hospitals, business servers and a city transit system [49][50][52]. In September a botnet of hacked internet-of-things devices, logging in with factory passwords, threw more than 620 Gbps at a journalist's website, and at least 1.1 Tbps at the hosting provider OVH [62][63]. Yahoo disclosed the theft of data from at least 500 million accounts in September and from more than one billion in December [80][81]. A group calling itself the Shadow Brokers published firewall exploits it said came from the Equation Group [47]. And on 17 December, for the second winter running, part of Ukraine lost power to a cyber attack; ESET judged it highly probable that purpose-built malware speaking the grid's own control protocols was used [18][19].

The government record of 2016 is unusually dense. On 7 October the US Intelligence Community said it was confident the Russian government had directed the compromises of US political email [3]. On 29 December the United States answered with sanctions on the GRU and FSB, the expulsion of 35 Russian officials, the closure of two compounds and a joint DHS and FBI report, GRIZZLY STEPPE, that for the first time attributed malicious cyber activity in a Joint Analysis Report to a named country [11][12][13][1]. The same year produced much of the decade's rulebook: the EU's GDPR and NIS Directive, the US cyber incident coordination directive PPD-41, New York's proposed financial cybersecurity regulation, the UK's national strategy and Investigatory Powers Act, and China's Cybersecurity Law [100][101][94][96][104][105][106].

This study is the dated record of that year, built only from sources opened on 11 November 2026. It covers state operations, ransomware and crime, the Mirai denial-of-service wave, exploited vulnerabilities, supply-chain, cloud and data breaches, and the government response. The Ukraine grid attacks, the Shadow

Brokers and Shamoon have home studies in this collection; this record gives each a summary paragraph and a link. Every row carries its date, the source that supports it and an evidence grade.

> Evidence grade: advisories, indictments (as allegations), sanctions, regulator findings, company filings, victim statements, vendor advisories, CVE records and the live ATT&CK pages are **Confirmed** from the issuing body. Facts that rest only on a secondary source (the Dyn outage, the Lurk arrests, the Panama Papers, the trojanized Transmission installers, the Andariel intrusion relayed by Treasury, China's Cybersecurity Law in translation) are **Reported**. Where this study draws its own conclusion, it says **Inferred**.

Key facts at a glance

Field	Value
Period	1 January to 31 December 2016, plus the 2016 publication of the December 2015 Ukraine outage and the later indictments, penalties and catalog entries that close 2016 events
Largest attempted theft	Bangladesh Bank, February 2016: $951 million attempted and $81 million unaccounted for (BAE); about $80 million stolen and $851 million attempted (Treasury) [26][27][29]
Largest denial of service	Mirai: more than 620 Gbps against KrebsOnSecurity on 20 September; at least 1.1 Tbps, possibly 1.5 Tbps, against OVH in late September [62][63]
Largest account disclosures	Yahoo: at least 500 million accounts (theft of late 2014, disclosed 22 September) and more than one billion (theft of August 2013, disclosed 14 December) [80][81]
Grid attack	17 December 2016: part of Kyiv without power for about one hour; ATT&CK campaign C0025, Sandworm Team with Industroyer [18][20]
Election intrusions	APT29 in a US political party from summer 2015, APT28 from spring 2016 (JAR); IC confidence statement on 7 October [1][3]
US response	29 December: sanctions on nine entities and individuals, 35 officials declared persona non grata, two compounds closed, JAR-16-20296A released [11][12][1]
Ransomware reported to the FBI	2,673 complaints and $2,431,261 in reported losses in 2016, against 298,728 complaints and $1.33 billion across all internet crime [51]
Exploited at or before disclosure	Flash CVE-2016-1019, CVE-2016-4117 and CVE-2016-7855, IE CVE-2016-0189, Win32k CVE-2016-7255, the iOS Trident chain, Dirty COW, Firefox CVE-2016-9079 [73][74][71][46][45][41][70][76]
2016 CVEs later in KEV	60 entries in the 2026.11.10 catalog, none added in 2016 because KEV began in 2021; 10 carry the known-ransomware flag (count Inferred from the catalog file) [65]
This study's MITRE binding	63 Enterprise and 22 ICS technique rows, 12 groups, 12 software objects and 2 campaigns, CWE-to-CAPEC pairings for the year's CVEs, and two Navigator layers (Part 9)

Key findings

- **Many of the year's intrusions turned on a credential (Inferred).** APT28's spring 2016 email sent recipients to a fake webmail page to change their passwords, and the stolen credentials opened the network (Confirmed [1]); the indictment alleges a DCCC employee's credentials were used on 12 April and the DNC reached on 18 April (Confirmed as allegation [5]). Mirai logged in with 62 default pairs (Confirmed [63]); Shamoon 2 spread with stolen domain admin credentials (Confirmed [32]); SamSam came in over RDP with brute-forced or stolen passwords (Confirmed [58]).
- **The banking system's trust model was attacked from inside a member bank.** The Bangladesh Bank malware worked with SWIFT Alliance Access (Confirmed [26]), and the New York Fed said the payment instructions were fully authenticated by SWIFT under standard protocols (Confirmed [30]). The fraudulent messages were valid; the bank sending them was compromised (Inferred).
- **Commodity IoT produced the year's largest attacks.** TA16-288A put the Krebs attack above 620 Gbps and the OVH attack at 1.1 Tbps or more, and noted that Mirai's source code went public at the end of September (Confirmed [63]). Mirai has no ATT&CK software object, so technique-only mapping understates it (Inferred [107]).
- **Grid attacks became automated.** Industroyer carried payloads for IEC 60870-5-101, IEC 60870-5-104, IEC 61850 and OPC DA (Confirmed [18]) and could issue valid commands directly to RTUs (Confirmed [19]). ESET called its use in the 17 December outage "highly probable" and named no state [18]; the US attribution to Russian actors came in the 2021 update [19].
- **Ransomware went after institutions, not only individuals.** TA16-091A reported Locky in hospitals in three countries and Samas entering healthcare networks through web servers (Confirmed [49]); the FBI said infections hit an all-time high in early 2016 and that newer variants charged per infected host (Confirmed [50]); at SFMTA ransomware affected about 900 office computers, and the agency switched off Muni Metro ticket machines and faregates as a precaution (Confirmed [52]).
- **Disclosure lagged far behind theft.** Yahoo's security team knew of the December 2014 intrusion within days but disclosed it in 2016 (Confirmed [83]); LinkedIn and Dropbox confirmed 2012 thefts in May and August 2016 (Confirmed [78][79]); Uber paid the intruders of fall 2016 $100,000 through its bug bounty and disclosed in November 2017 (Confirmed [85]).
- **Governments moved from warning to naming.** The October joint statement, the December JAR and sanctions (Confirmed [3][1][11]), the 2018 indictment that dates individual 2016 steps to the day (Confirmed as allegations [5]) and the 2020 Sandworm indictment (Confirmed as allegation [23]) make 2016 one of the best-documented years of state activity (Inferred). The scanning of state election systems was explicitly not attributed in October 2016 (Confirmed [3]).

Top recommendations

1. **Replace default and reused credentials everywhere they can reach the internet.** TA16-288A's first mitigation was changing default passwords, and the 2016 record repeats the lesson for webmail, domain admin and RDP accounts (Confirmed [63][1][32][58]).
2. **Put multi-factor authentication on webmail, remote access and administration.** AA18-337A lists two-factor authentication against SamSam's RDP access, and the JAR's top mitigations include restricting administrative privileges (Confirmed [58][1]).

3. **Treat payment-message endpoints as tier-zero systems.** Monitor the hosts that build and send SWIFT or equivalent messages, and reconcile what was sent with what the counterparty received; the Bangladesh malware worked with SWIFT Alliance Access (Confirmed [26]), and ATT&CK maps APT38's DYEPACK to altering SWIFT records and removing traces (Confirmed [28]; the tie to the Bangladesh case and the recommendation are Inferred).
4. **Keep offline, tested backups and use them.** SFMTA restored from backups and never considered paying (Confirmed [52]); AA18-337A and TA17-163A both call for backups, the latter as gold images for control systems (Confirmed [58][19]).
5. **Separate and inspect control networks.** TA17-163A asks for application allowlisting, authentication and authorization for ICS commands, firewalls that inspect commands, separate corporate and control credentials, and monitoring at ICS boundaries (Confirmed [19]).
6. **Patch the exploited bug first, and plan for the later catalog.** Every 2016 CVE now in KEV was added from 2021 onward (Inferred count [65]); the exploited-in-the-wild notes in vendor bulletins (MS16-051, MS16-135, MFSA 2016-92) were the signal at the time (Confirmed [46][45][76]).
7. **Disclose on a clock, not on a deal.** The SEC fined Altaba $35 million for withholding the 2014 Yahoo breach while selling its business, and the FTC acted on Uber's concealment (Confirmed [83][85]).

Scope and method

This study covers intrusions, campaigns and disclosures dated to 2016, plus the later records (indictments, regulator findings, catalog entries) that close a 2016 event. It follows the method of the case studies collection: primary sources first, every event graded, numbers as the source states them.

Grade	Meaning in this study
Confirmed	The primary source (agency advisory, court or charging document, sanctions notice, regulator finding, company filing, victim statement, the vendor's own research or advisory, NVD, KEV, a live ATT&CK page) was opened on 11 November 2026 and states the fact. Charging documents are cited as allegations
Reported	Only a secondary source (press, or vendor research that relays someone else's finding, or vendor research not corroborated by the affected project (Transmission's own notice did not open)) was opened for the fact
Demonstrated	Public proof-of-concept code exists; it shows a flaw can be used, not that it was. No 2016 claim in this study rests on this grade
Inferred	The study's own reasoning, labelled where it appears

Limits that a reader should know:

- **Pages that refused automated access.** The US Department of Justice press releases and the July 2018 indictment, and the ODNI assessment, were read from Internet Archive snapshots of the original government URLs; the cited URL is the snapshot that was opened. Dyn's own account of the 21 October attack, Europol's Avalanche release, the Federal Register entry for the order amending EO 13694, the FBI wanted pages, the Mirai guilty pleas, the SamSam indictment, and the Hollywood Presbyterian and MedStar statements did not open. Those events are either left out or carried at the grade of what did open.

- **Vendor counts are vendor counts.** FBI complaint totals are self-reported and the FBI says most victims do not report [50][51]; Microsoft's and Kaspersky's figures describe what they saw.
- **Attribution is reported as the source gives it.** A vendor's "highly probable" stays highly probable; a press report relayed by Treasury stays Reported; a DOJ indictment is an allegation.
- **Home studies.** The 2015 and 2016 Ukraine grid attacks live in the Sandworm study; the Shadow Brokers in the United States-attributed actors study; Shamoon's history in the Iran-attributed actors study. Each is summarized here in a paragraph.
- **Tradecraft is described at advisory level.** Technique names and ids only; no commands, exploit details, payload strings or ransom notes.

Part 1: the year as a dated timeline

One row per event or report. The date is the event date where the source gives one, otherwise the publication date.

Date	Event	Thread	Grade	Sources
2015-12-23	Remote intrusions at three Ukrainian regional distribution companies cut power to about 225,000 customers; attacks at each within 30 minutes; KillDisk wipes systems; BlackEnergy found, role unknown. Recorded in the alert released in 2016. Home study: Sandworm	ICS	Confirmed	[16][17]
2016-02-09	Cybersecurity National Action Plan: a Commission on Enhancing National Cybersecurity, a Federal CISO post, a proposed $3.1 billion IT Modernization Fund and a FY2017 request of over $19 billion	Government	Confirmed	[93]
2016-02	An attacker in Bangladesh Bank's SWIFT system attempts $951 million in transfers from its New York Fed account; $81 million is not recovered	State, finance	Confirmed	[26][29]
2016-02-20	Attackers backdoor the Linux Mint 17.3 Cinnamon ISO and point the download links at it	Supply chain	Confirmed	[90]
2016-02-23	FTC settles with ASUS over insecure routers and cloud services; attackers had reached over 12,900 consumers' storage devices in February 2014	Regulator	Confirmed	[86]
2016-02-25	ICS-CERT releases IR-ALERT-H-16-056-01 on the Ukraine outage (date Inferred from the alert number)	ICS	Confirmed (date Inferred)	[16]
2016-03-01	DROWN, CVE-2016-0800, an SSLv2 protocol flaw, published in NVD	Vulnerability	Confirmed	[66]
2016-03-02	CFPB's first data security action: Dwolla, $100,000 penalty	Regulator	Confirmed	[89]
2016-03-04 to 2016-03-05	KeRanger ransomware ships in two Transmission 2.90 installers on the official site, signed with a valid Apple developer certificate	Supply chain, ransomware	Reported	[53]
2016-03-09	The New York Fed says it has no evidence its systems were penetrated and that the Bangladesh payment instructions were fully authenticated by SWIFT	Finance	Confirmed	[30]

Date	Event	Thread	Grade	Sources
2016-03-19	GRU Unit 26165 officers spear phish the Clinton campaign chairman, then other campaign figures (indictment allegation)	State	Confirmed	[5]
2016-03-22	A maintainer unpublishes kik and 272 other npm packages, including left-pad; installs fail for about 2.5 hours	Supply chain	Confirmed	[92]
2016-03-23	Su Bin pleads guilty to conspiring with two persons in China (2008 to 2014) to hack US defense contractors	Government	Confirmed	[34]
2016-03-24	Indictment of seven Iranians from ITSecTeam and Mersad unsealed for DDoS on 46 mostly financial victims (late 2011 to mid-2013) and 2013 access to the Bowman Dam SCADA system	Government	Confirmed	[31]
2016-03-31	TA16-091A with Canada's CCIRC: Locky in hospitals in the US, New Zealand and Germany; Samas into healthcare networks through web servers	Ransomware	Confirmed	[49]
Early 2016	SamSam actors exploit JBoss servers; SamSam (S0370) "appeared in early 2016"	Ransomware	Confirmed	[58][59]
2016-04	Flash CVE-2016-1019 exploited in the wild (NVD published 7 April)	Vulnerability	Confirmed	[73]
2016-04-03	ICIJ publishes the Panama Papers, 11.5 million records from an offshore law firm	Data breach	Reported	[87]
2016-04 (spring)	APT28 enters a US political party (JAR); CrowdStrike dates FANCY BEAR's breach of the DNC to April	State	Confirmed	[1][7]
2016-04-12	Badlock, CVE-2016-2118 in Samba, published in NVD	Vulnerability	Confirmed	[67]
2016-04-12 and 2016-04-18	Stolen DCCC credentials used to enter the DCCC network; the DNC reached through that access; X-Agent keylogging and screenshots turned on (indictment allegation)	State	Confirmed	[5]
2016-04-14	The European Parliament gives final approval to the EU data protection reform	Government	Confirmed	[99]
2016-04-25	BAE Systems publishes its analysis of the Bangladesh Bank malware	Finance	Confirmed	[26]
2016-04-27	Regulation (EU) 2016/679 (GDPR) dated; in force 24 May 2016, applicable 25 May 2018	Government	Confirmed	[100]
2016-05 (early)	PROMETHIUM and NEODYMIUM both use Flash zero-day CVE-2016-4117 against individuals in Europe; NVD publishes it on 11 May	State, vulnerability	Confirmed	[38][74]
2016-05-01	CrowdStrike begins work with the DNC	State	Confirmed	[7]
2016-05-05	ImageTragick, CVE-2016-3714 in ImageMagick, published in NVD	Vulnerability	Confirmed	[68]
2016-05-10	MS16-051: IE scripting engine CVE-2016-0189 marked Exploited: Yes	Vulnerability	Confirmed	[46]
2016-05-11	TA16-132A: at least 36 organizations worldwide affected by exploitation of an SAP vulnerability	Exploitation	Confirmed	[77]

Date	Event	Thread	Grade	Sources
2016-05-18	LinkedIn: email and hashed password data for more than 100 million members from the 2012 theft released	Data breach	Confirmed	[78]
2016-05-23	Swiss GovCERT publishes its technical report on the RUAG espionage case (Turla-family malware)	State	Confirmed	[39]
2016-06 (early)	Russian police arrest alleged members of the Lurk banking-trojan group, as Kaspersky relays it	Crime	Reported	[56]
2016-06-08	SEC: Morgan Stanley Smith Barney pays $1 million under the Safeguards Rule after an employee copied data on about 730,000 accounts	Regulator	Confirmed	[88]
2016-06-14	CrowdStrike publishes "Bears in the Midst": COZY BEAR in the DNC since summer 2015, FANCY BEAR separately from April 2016	State	Confirmed	[7]
2016-06-15	A Moscow-based server searches for phrases that later appear in Guccifer 2.0's first post (DOJ allegation)	State	Confirmed	[6]
2016-07-06	Directive (EU) 2016/1148 (NIS) dated; in force 8 August 2016	Government	Confirmed	[101]
2016-07-08	Kaspersky publishes the Dropping Elephant actor (Patchwork, G0040)	State	Confirmed	[37]
2016-07-09	NATO's Warsaw communique recognizes cyberspace as a domain of operations and records the Cyber Defence Pledge	Government	Confirmed	[103]
2016-07-12	The European Commission adopts the EU-U.S. Privacy Shield	Government	Confirmed	[102]
2016-07	GRU Unit 74455 officers hack a state board of elections website and steal records on about 500,000 voters (indictment allegation)	State	Confirmed	[5]
2016-07-25	No More Ransom launches (Dutch National Police, Europol, Intel Security, Kaspersky Lab)	Crime	Confirmed	[54][55]
2016-07-26	PPD-41, United States Cyber Incident Coordination	Government	Confirmed	[94]
2016-08-08	Kaspersky publishes ProjectSauron (Strider, G0041): June 2011 to April 2016, more than 30 organizations	State	Confirmed	[35][36]
2016-08-10 and 2016-08-11	Ahmed Mansoor receives SMS links to NSO Group exploit infrastructure	State, mobile	Confirmed	[40]
2016-08-15	Cisco is alerted to Shadow Brokers material claiming Equation Group disclosures, including exploits for PIX and ASA	Leak	Confirmed	[47]
2016-08-17	Cisco advisory for CVE-2016-6366 (ASA SNMP); NVD publishes it on 18 August	Vulnerability	Confirmed	[47][48]
2016-08-24 and 2016-08-25	Citizen Lab publishes the Trident report; Apple ships iOS 9.3.5 fixing CVE-2016-4655, -4656 and -4657	State, vulnerability	Confirmed	[40][41]

Date	Event	Thread	Grade	Sources
2016-08-25	Dropbox confirms a list of 68 million credentials, likely from 2012, is real (updated 31 August)	Data breach	Confirmed	[79]
2016-08-28 to 2016-08-29	A trojanized Transmission 2.92 on the official site carries OSX/Keydnap	Supply chain	Reported	[91]
2016-09	Andariel intrudes into the South Korean Defense Minister's computer and the Defense Ministry intranet, as Treasury relays industry and press reporting	State	Reported	[27]
2016-09-07	House Oversight staff report on the 2015 OPM breach	Government	Confirmed	[95]
2016-09-13	WADA confirms APT28 accessed its ADAMS database through an IOC-created Rio 2016 account; NYDFS proposes its cybersecurity regulation	State, government	Confirmed	[14][96]
2016-09-15	FBI PSA I-091516-PSA asks ransomware victims to report	Ransomware	Confirmed	[50]
2016-09-20	A DDoS of about 620 Gbps hits KrebsOnSecurity from about 8 p.m. ET; Akamai absorbs it	IoT, DDoS	Confirmed	[62][63]
2016-09-22	Yahoo discloses the theft of data from at least 500 million accounts in late 2014	Data breach	Confirmed	[80]
2016-09 (late)	Mirai hits OVH with at least 1.1 Tbps; Mirai's source code is published at the end of September	IoT, DDoS	Confirmed	[63]
2016-10	Dirty COW, CVE-2016-5195, exploited in the wild; Flash CVE-2016-7855 exploited in the wild	Vulnerability	Confirmed	[70][71]
2016-10-07	DHS and ODNI joint statement on Russian-directed email compromises	Government	Confirmed	[3]
2016-10-14	TA16-288A on Mirai and other botnets	Advisory	Confirmed	[63]
2016-10-21	A DDoS on Dyn disrupts major sites; Flashpoint says a Mirai botnet of DVRs and IP cameras took part	IoT, DDoS	Reported	[64]
2016-10-31	Google Online Security Blog post "Disclosing vulnerabilities to protect users" (date only read)	Vulnerability	Confirmed (date only)	[44]
2016-11-01	Microsoft: STRONTIUM used Flash and Windows kernel zero-days; UK National Cyber Security Strategy 2016 to 2021 published	State, government	Confirmed	[43][104]
2016-11-05 to 2016-11-07	Tesco Bank attack: 48 hours, GBP 2.26 million taken, 8,261 of 131,000 personal current accounts affected	Crime	Confirmed	[60][61]
2016-11-07	China's Cybersecurity Law passed (effective 1 June 2017)	Government	Reported	[106]
2016-11-08	MS16-135 fixes Win32k CVE-2016-7255, marked publicly disclosed and exploited	Vulnerability	Confirmed	[45]
2016-11-09	Volexity reports five post-election spear-phishing waves against US think tanks and NGOs and believes The Dukes (APT29) responsible	State	Confirmed	[8]
2016-11	JAR: a spear-phishing campaign "as recently as November 2016, just days after the U.S. election"	State	Confirmed	[1]

Date	Event	Thread	Grade	Sources
2016 (fall)	Intruders use an access key an Uber engineer posted on a code-sharing site to reach consumer data in third-party cloud storage	Cloud, data breach	Confirmed	[85][84]
2016-11-17 20:45	Shamoon 2's hardcoded wipe time against at least one Saudi organization	Wiper	Confirmed	[32]
2016-11-25	SFMTA learns of ransomware on about 900 office computers	Ransomware	Confirmed	[52]
2016-11-29	UK Investigatory Powers Act 2016 enacted	Government	Confirmed	[105]
2016-11-30	MFSA 2016-92: Firefox SVG use-after-free CVE-2016-9079 exploited against Firefox and Tor Browser users; Unit 42 publishes Shamoon 2	Vulnerability, wiper	Confirmed	[76][32]
2016-11 (late)	A Mirai variant targets TCP port 7547 (TA16-288A update)	IoT	Confirmed	[63]
2016-12-01	TA16-336A on the Avalanche crimeware-as-a-service network; the Commission on Enhancing National Cybersecurity issues its final report	Crime, government	Confirmed	[57][97]
2016-12	FDA final guidance on postmarket management of cybersecurity in medical devices	Government	Confirmed	[98]
2016-12-13	ESET names TeleBots for second-half-2016 attacks on Ukraine's financial sector	State	Confirmed	[24]
2016-12-14	Yahoo discloses theft from more than one billion accounts in August 2013 and forged-cookie access; Microsoft publishes PROMETHIUM and NEODYMIUM; NVD publishes NETGEAR CVE-2016-6277	Data breach, state	Confirmed	[81][38][75]
2016-12-17	Part of Kyiv without power for about one hour; Industroyer "highly probable" (ESET). Home study: Sandworm	ICS	Confirmed	[18][19][20]
2016-12-29	Sanctions, expulsions and compound closures; Treasury designates Bogachev and Belan; DHS and FBI release JAR-16-20296A	Government	Confirmed	[11][12][13][1]

Records after 2016 that close 2016 events:

Date	Event	Sources
2017-01-06	ODNI assessment: high confidence Putin ordered a 2016 influence campaign (NSA moderate on one judgment)	[4]
2017-06-12	ESET's Industroyer report and US-CERT TA17-163A on CrashOverride	[18][19]
2017-11-21	Uber's statement on the 2016 incident	[84]
2018-04	SEC fines Altaba $35 million over the 2014 Yahoo breach; FTC expands its Uber settlement	[83][85]
2018-07-13	Grand jury charges 12 GRU officers over the 2016 election intrusions and releases	[5][6]
2018-09-06	DOJ charges Park Jin Hyok in the Bangladesh Bank conspiracy	[29]
2018-10-01	FCA Final Notice to Tesco Bank, GBP 16.4 million penalty	[60][61]

Date	Event	Sources
2018-10-04	DOJ charges seven GRU officers over anti-doping operations	[15]
2018-12-03	CISA AA18-337A on SamSam	[58]
2019-09-13	Treasury designates Lazarus Group, Bluenoroff and Andariel	[27]
2020-10-15	Six GRU Unit 74455 officers charged, including for the 2015 and 2016 Ukraine attacks	[23]
2021-07-20	CISA updates IR-ALERT-H-16-056-01 and TA17-163A to attribute the activity to Russian nation-state actors	[16][19]
2021-11-03 to 2026-10-08	KEV lists 60 CVE-2016 entries, the last (Struts CVE-2016-3081) added on 8 October 2026	[65]

Part 2: state operations

Russia: the US election intrusions

The government record begins with a two-sentence finding. The JAR of 29 December 2016 says the US Government confirms two Russian intelligence actors intruded into "a U.S. political party": APT29 entered in summer 2015 and APT28 in spring 2016 (Confirmed [1]). It describes how. The 2015 APT29 campaign sent malicious-link emails to over 1,000 recipients, including multiple US Government victims, then established persistence, escalated privileges, enumerated Active Directory accounts and exfiltrated email over encrypted connections (Confirmed [1]). The spring 2016 APT28 email led recipients to change their passwords on a fake webmail domain; the harvested credentials were used to access and steal content, and the JAR notes the actor's lookalike domains and shortened URLs (Confirmed [1]). Actors "likely associated with" Russian intelligence ran another spear-phishing campaign days after the election (Confirmed [1]). The JAR says it is the first such report to attribute activity to a country, and that it expands on the joint statement of 7 October (Confirmed [1]).

CrowdStrike's account, first published on 14 June 2016, put COZY BEAR in the DNC network from summer 2015 and FANCY BEAR there separately from April 2016, named malware including SeaDaddy, X-Agent and X-Tunnel, and dated its own engagement from 1 May 2016 (Confirmed [7]). The same page says the FBI first alerted the DNC in September 2015, citing a DNC IT contractor's testimony; that point is secondary (Reported [7]).

On 7 October DHS and ODNI said the Intelligence Community was confident the Russian Government directed the recent compromises of email of US persons and institutions, including political organizations, and that the disclosures on DCLeaks, WikiLeaks and by Guccifer 2.0 were consistent with Russian methods. They also said they were "not now in a position to attribute" scanning of some states' election systems, most of it from servers run by a Russian company (Confirmed [3]). The January 2017 assessment states high confidence that President Putin ordered a 2016 influence campaign, with the NSA at moderate confidence on one judgment; places Russian intelligence in DNC networks from July 2015 to at least June 2016; says the GRU probably began election-related operations by March 2016; and says Russian intelligence accessed elements of multiple state or local electoral boards (Confirmed [4]).

The July 2018 indictment dates the steps, as allegations. On or about 19 March 2016, Unit 26165 officers spear phished the Clinton campaign chairman and then other campaign figures. On 12 April they used a DCCC employee's stolen credentials to enter the DCCC network; on 18 April they reached the DNC through that access, and X-Agent's keylogging and screenshot functions were turned on. X-Tunnel moved stolen documents out over encrypted channels, and compressed DNC data went to a GRU-leased computer in Illinois. In or around July 2016, Unit 74455 officers hacked a state board of elections website and stole records on about 500,000 voters (Confirmed as allegations [5]). DOJ's release adds that on 15 June 2016 a Moscow-based server searched for phrases that later appeared in Guccifer 2.0's first post (Confirmed as allegation [6]).

After the election, Volexity saw five spear-phishing waves against US think tanks and NGOs from 9 November and "believes" The Dukes (APT29) were responsible; ATT&CK lists PowerDuke (S0139) as used by APT29 in 2016 (Confirmed [8][108]).

ATT&CK's own pages hold the line the sources hold. G0007 APT28 is attributed to GRU unit 26165 and "reportedly compromised" the Clinton campaign, DNC and DCCC in 2016; G0016 APT29 is attributed to the SVR and reportedly compromised the DNC from summer 2015 (Confirmed [9][10]). The group profiles live in the Russia-attributed actors study; APT29's later supply-chain operation is the subject of the SolarWinds study. The DNC intrusions are also read against their court and advisory record in the Fancy Bear Goes Phishing cases study and, as an instrument of state policy, in the Hacker and the State cases study.

Russia: anti-doping and the Rio Games

WADA confirmed on 13 September 2016 that APT28 ("Tsar Team", Fancy Bear) had accessed its ADAMS database through an account the IOC created for the Rio 2016 Games, obtained by spear phishing, and had released confidential athlete data including Therapeutic Use Exemptions (Confirmed [14]). ATT&CK records that APT28 also ran a DDoS attack against WADA in 2016 (Confirmed [9]). In October 2018 DOJ charged seven GRU officers over operations from about December 2014 to May 2018 against anti-doping bodies after the McLaren report: exemption data was stolen and leaked as "Fancy Bears' Hack Team", and close-access teams hacked Wi-Fi networks, including hotel Wi-Fi (Confirmed as allegation [15]).

Russia and Ukraine: the grid, the treasury and the banks (summary)

The home study for this thread is Sandworm: the operations in the public record. In brief: the ICS-CERT alert released in February 2016 recorded the 23 December 2015 outage at three oblenergos, about 225,000 customers, KillDisk wiping, firmware corruption of serial-to-Ethernet devices at substations and scheduled UPS disconnects, and in 2016 called BlackEnergy's role unknown (Confirmed [16]). ATT&CK records it as campaign C0028, Sandworm Team with BlackEnergy and KillDisk, December 2015 to January 2016 (Confirmed [17]). In the second half of 2016 ESET tracked TeleBots attacks on Ukraine's financial sector, delivered by spear phishing with macro-laden Excel attachments, and said "we think" the BlackEnergy group evolved into TeleBots (Confirmed [24]). On 17 December 2016 part of Kyiv lost power for about an hour; ESET called it "highly probable" that Industroyer was used, citing a matching activation timestamp, and named no state (Confirmed [18]). TA17-163A said CrashOverride was "reportedly used in 2016" and added the US attribution to Russian nation-state actors only in its 20 July 2021 update (Confirmed [19]). ATT&CK records the attack as campaign C0025, Sandworm Team with Industroyer, December 2016 (Confirmed [20][21]), and attributes Sandworm Team to GRU GTsST unit 74455 (Confirmed [22]). In October 2020 DOJ charged six Unit 74455 officers over destructive attacks from December 2015 to December 2016 on Ukraine's grid, Ministry of Finance and State Treasury Service, using BlackEnergy, Industroyer and KillDisk (Confirmed as allegation [23]). ESET's title set Industroyer beside Stuxnet [18].

North Korea: the Bangladesh Bank theft

BAE Systems published its analysis on 25 April 2016: in February an attacker had accessed Bangladesh Bank's SWIFT system and attempted to move $951 million, of which $81 million remained unaccounted for. The custom malware interacted with SWIFT Alliance Access and registered itself as a service; in April 2016 BAE called the attacker unknown (Confirmed [26]). The New York Fed said on 9 March that it had no evidence of any attempt to penetrate Fed systems and that the payment instructions were fully authenticated by SWIFT under standard protocols (Confirmed [30]).

Attribution came later. DOJ's September 2018 complaint alleges the conspiracy stole $81 million in February 2016 through spear phishing and fraudulent SWIFT messages to the New York Fed, alleges Park Jin Hyok belongs to the "Lazarus Group" (G0032), and notes OFAC designated him and KEJV under EO 13722 (Confirmed as allegation [29]). Treasury's 2019 designation of Lazarus Group, Bluenoroff and Andariel says Bluenoroff and Lazarus stole about $80 million from the bank's New York Fed account, making over 36 large transfer requests with stolen SWIFT credentials and attempting $851 million in all (Confirmed [27]). ATT&CK lists the 2016 Bank of Bangladesh heist under APT38 (G0082), attributes APT38 to the RGB, notes that some researchers report all DPRK activity as Lazarus Group, and maps DYEPACK's manipulation of SWIFT records, messages and traces (Confirmed [28]). Treasury also relays industry and press reporting that in September 2016 Andariel intruded into the South Korean Defense Minister's computer and the Defense Ministry intranet (Reported [27]). The North Korean groups are profiled in the North Korea-attributed actors study, and the heist's attribution record is also set out in the Hacker and the State cases study.

Iran: the March indictment and Shamoon 2

On 24 March 2016 DOJ unsealed an indictment of seven Iranians from ITSecTeam and Mersad, companies it says worked for the Iranian Government including the IRGC, for more than 176 days of DDoS attacks on 46 mostly financial victims from late 2011 to mid-2013, and for 2013 access to the Bowman Dam SCADA system (Confirmed as allegation [31]). The conduct predates 2016; the indictment is the 2016 event.

Shamoon returned on 17 November. Unit 42 found Disttrack samples set to wipe at 20:45 that day against at least one Saudi organization. They spread with hardcoded stolen domain admin credentials, a scan of the local /24, remote copying and execution by service or scheduled task, then wiped files, the MBR and partition tables through a raw-disk driver and forced a reboot. Unit 42 named no state (Confirmed [32]). ATT&CK S0140 records Shamoon as first used in 2012 by a group calling itself Cutting Sword of Justice and Shamoon 2 as observed in 2016; the pages opened do not tie Shamoon 2 to APT33 (G0064) (Confirmed [33]). Shamoon's longer history is in the Iran-attributed actors study.

China: the Su Bin plea

On 23 March 2016 Su Bin pleaded guilty to conspiring with "two persons in China" from 2008 to 2014 to hack US defense contractors, including Boeing, for C-17 and fighter jet data. The release does not name the PLA (Confirmed [34]). This study found no ATT&CK group object tied to the case in the library data (Inferred [107]); China-attributed groups are profiled in the China-attributed actors study.

Vendor-named espionage clusters

- **ProjectSauron (Strider, G0041).** Kaspersky reported on 8 August 2016 a platform operational from at least June 2011 to April 2016 against more than 30 organizations, including key governmental entities, in Russia, Iran, Rwanda and possibly Italian-speaking countries. The text opened names no state; ATT&CK's G0041 carries no attribution and lists victims in Russia, China, Sweden, Belgium, Iran and Rwanda (Confirmed [35][36]).
- **Dropping Elephant (Patchwork, G0040).** Kaspersky on 8 July 2016: targets tied to China's foreign relations, reached by spear phishing and watering holes, with operators sometimes logging in from an Indian ISP. ATT&CK says the group is not definitively attributed and may be a pro-Indian or Indian entity (Confirmed [37]).
- **PROMETHIUM (G0056) and NEODYMIUM (G0055).** Microsoft reported on 14 December 2016 that both groups used the then-unpatched Flash zero-day CVE-2016-4117 against individuals in Europe in early May 2016. Microsoft names no state; ATT&CK notes their heavy Turkish targeting (Confirmed [38]). Both groups are profiled in the other state-linked actors study.
- **RUAG and Turla.** Swiss GovCERT published its technical report on the espionage case against the defense company RUAG on 23 May 2016 and said the attackers used malware from the Turla family. Mapping that to ATT&CK G0010 Turla is this study's inference (Confirmed [39]; mapping Inferred).

Mobile surveillance: Trident and Pegasus

On 10 and 11 August 2016 the UAE human-rights defender Ahmed Mansoor received SMS messages with links to NSO Group exploit infrastructure. Citizen Lab found that the links led to a chain of three iOS zero-days, which it named Trident (CVE-2016-4657, CVE-2016-4655, CVE-2016-4656), that would have installed Pegasus. Its report came out with Apple's patch about 10 days after disclosure to Apple (Confirmed [40]). Apple's iOS 9.3.5 notes credit Citizen Lab and Lookout for the three fixes (Confirmed [41]). KEV added all three on 24 May 2022 (Confirmed [65]). ATT&CK records the implant as S0289 Pegasus for iOS, a Mobile object reportedly linked to NSO Group; the library has no generated page for it (Confirmed [42][107]). The commercial spyware record from Trident onward is in the zero-day trade study.

STRONTIUM's autumn zero-days

Microsoft said on 1 November 2016 that STRONTIUM (APT28 in the library's alias list) ran a low-volume spear-phishing campaign using zero-days in Adobe Flash and the down-level Windows kernel, first identified by Google's Threat Analysis Group, and that it attributed more 2016 zero-days to STRONTIUM than to any other group (Confirmed [43]). Google's post on the disclosure is dated 31 October 2016; only its date was read (Confirmed [44]). Microsoft names the Flash bug as CVE-2016-7855 (Confirmed [43][71]). The Windows bug is the Win32k flaw fixed in MS16-135 on 8 November as CVE-2016-7255, marked publicly disclosed and exploited (Confirmed [45][72]); tying that CVE to STRONTIUM is this study's reading (Inferred).

Part 3: ransomware and crime

Hospitals and servers

TA16-091A, released on 31 March 2016 with Canada's CCIRC, is the year's first ransomware warning in the record. It names Locky, which in early 2016 infected healthcare facilities and hospitals in the US, New Zealand and Germany through spam with malicious Office documents or compressed attachments using macros or JavaScript, and Samas, which compromised healthcare networks through vulnerable web servers. Typical individual demands were $200 to $400 in Bitcoin (Confirmed [49]).

Samas is SamSam. CISA's 2018 advisory says the actors exploited JBoss servers in early 2016 and from mid-2016 entered over RDP with brute-forced or stolen credentials (Confirmed [58]). ATT&CK's S0370 SamSam says it appeared in early 2016 but maps only execution, encryption and defense-evasion techniques and lists no group, so the initial-access techniques in Part 9 come from CISA, not ATT&CK (Confirmed [59]).

The FBI's September PSA said infections were at an all-time high in early 2016, that one variant compromised an estimated 100,000 computers a day in its first weeks, that recent variants targeted business servers and charged per infected host, and that some victims who paid did not get keys for all files or were extorted again (Confirmed [50]). The IC3's 2016 report records 2,673 ransomware complaints with $2,431,261 in losses and names phishing and RDP as vectors (Confirmed [51]). Those figures are self-reported and small next to the 12,005 business email compromise complaints, with more than $360 million in losses, in the same report (Confirmed [51]).

Mac ransomware and San Francisco Muni

Unit 42 reported KeRanger, which it called the first fully functional OS X ransomware, in two Transmission 2.90 installers on the official site on 4 and 5 March. They were signed with a valid Apple developer certificate; Apple revoked it and updated XProtect, and Transmission removed the installers on 5 March. The demand was 1 BTC, about $400 (Reported [53]).

On 25 November SFMTA learned of ransomware on about 900 office computers. Transit operations, safety and payment systems were not affected and no customer data was accessed; the agency chose to switch off Muni Metro ticket machines and faregates until Sunday morning, never considered paying, and restored from backups (Confirmed [52]).

The response: No More Ransom

No More Ransom launched on 25 July 2016, founded by the Dutch National Police, Europol, Intel Security and Kaspersky Lab; the launch release cites one decryption tool holding more than 160,000 keys (Confirmed [54]). The project's own page names its founders as the Dutch National High Tech Crime Unit, Europol's EC3, Kaspersky and McAfee, and advises victims not to pay (Confirmed [55]).

Banking fraud and crimeware infrastructure

- **Tesco Bank.** The attack began at 02:00 on Saturday 5 November 2016 and ran for 48 hours, netting GBP 2.26 million and affecting 8,261 of 131,000 personal current accounts. The FCA fined the bank GBP 16.4 million in October 2018 (the Final Notice says it would otherwise have been GBP 23,428,500) for weaknesses in its debit card design, financial crime controls and Financial Crime Operations Team (Confirmed [60][61]).
- **Lurk.** Kaspersky reports that Russian police arrested alleged members of the Lurk banking-trojan group in early June 2016 and suspected theft of nearly three billion rubles (Reported [56]).
- **Avalanche.** TA16-336A, released on 1 December 2016, describes a crimeware-as-a-service hosting network that used fast-flux DNS behind compromised proxies to host Citadel, Dridex, Emotet, GozNym, TeslaCrypt, Marcher and other families, with malware aimed at more than 40 major financial institutions. The takedown figures were not checked because the Europol and DOJ pages did not open (Confirmed [57]).
- **Bogachev and Belan.** On 29 December Treasury designated Evgeniy Bogachev (Zeus, and Cryptolocker with over 120,000 US victims and over $100 million stolen) and Aleksey Belan (three US e-commerce companies, about 200 million accounts) under the amended EO 13694 (Confirmed [13]).

Part 4: Mirai and the IoT denial-of-service wave

On 20 September 2016, from about 8 p.m. ET, a DDoS against KrebsOnSecurity peaked near 620 Gbps. In his own post the next day Brian Krebs wrote that it failed because Akamai absorbed it, used no amplification or reflection, and appeared to come from hacked IoT devices (Confirmed [62]). TA16-288A, released on 14 October, tied that attack to Mirai, reported a late-September Mirai attack on OVH of at least 1.1 Tbps and possibly 1.5 Tbps, said Mirai logs in with 62 common default username and password pairs, and said its source code was published at the end of September (Confirmed [63]). A later update notes a late-November variant aimed at TCP 7547 and tells defenders to watch Telnet on TCP 23 and 2323 (Confirmed [63]). Its mitigations are changing default passwords, patching, disabling UPnP, buying from vendors with strong security records, and rebooting offline and then changing the password to clear an infection (Confirmed [63]).

On 21 October a DDoS against the DNS provider Dyn disrupted Twitter, Amazon, Tumblr, Reddit, Spotify and Netflix. Krebs reported Flashpoint's finding that a Mirai botnet of XiongMai DVRs and IP cameras took part, without ruling out other botnets (Reported [64]). Dyn's own account did not open, and TA16-288A does not mention Dyn [63]. The Dyn outage is the best-known Mirai event and the least well-sourced one in this record.

ATT&CK has no software object for Mirai, Bashlite or Gafgyt, so the Mirai rows in Part 9 bind techniques only (Confirmed [107]). Mirai's authors, court filings and measurement record are the subject of a chapter in the Fancy Bear Goes Phishing cases study.

Part 5: vulnerabilities and exploitation

The zero-days of record

Vendor bulletins and NVD records mark a run of 2016 bugs as exploited before or at disclosure: Flash CVE-2016-1019 in April and CVE-2016-4117 in May (Confirmed [73][74]); IE scripting engine CVE-2016-0189 in MS16-051 on 10 May, exploited and not publicly disclosed (Confirmed [46]); the Trident iOS chain in August (Confirmed [40][41]); Dirty COW, a Linux kernel copy-on-write race giving local privilege escalation, exploited in October (Confirmed [70]); Flash CVE-2016-7855 in October and Win32k CVE-2016-7255 in November (Confirmed [71][45]); Microsoft ties the Flash bug to STRONTIUM [43], and the Win32k tie is Inferred; and Firefox CVE-2016-9079, an SVG animation use-after-free exploited against Firefox and Tor Browser users on Windows and fixed in Firefox 50.0.2 on 30 November (Confirmed [76]).

The Shadow Brokers' first release (summary)

The home study for the leaks is United States-attributed threat actors, which carries the August 2016 sample archive and the April 2017 release. For this year: Cisco was alerted on 15 August 2016 to material posted by the Shadow Brokers, who claimed it came from the Equation Group (G0020), including exploits for Cisco PIX and ASA; Cisco's advisory of 17 August covers CVE-2016-6366, an ASA SNMP buffer overflow whose exploit the group had disclosed, with workarounds that restrict SNMP to trusted hosts and call for strong community strings (Confirmed [47]). NVD published CVE-2016-6366 on 18 August, and KEV added it and the ASA CLI flaw CVE-2016-6367, also in the August material (fix history in the United States-attributed actors study), on 24 May 2022 (Confirmed [48][65]). The leaks' place in the zero-day market, through the April 2017 release and WannaCry, is traced in the zero-day trade study.

Named bugs and enterprise exposure

- **DROWN** (CVE-2016-0800), an SSLv2 protocol flaw in OpenSSL and other products, published 1 March; not in KEV (Confirmed [66][65]).
- **Badlock** (CVE-2016-2118), in Samba's MS-SAMR and MS-LSAD handling, published 12 April; not in KEV (Confirmed [67][65]).
- **ImageTragick** (CVE-2016-3714), ImageMagick input validation allowing code execution through a crafted image, published 5 May; added to KEV on 9 September 2024 (Confirmed [68][65]).
- **SAP Invoker Servlet.** TA16-132A on 11 May reported exploitation at 36 or more organizations worldwide, found by Onapsis, with SAP Security Note 1445998 and disabling the Invoker Servlet as the fix (Confirmed [77]).
- **NETGEAR routers** (CVE-2016-6277), remote code execution, published 14 December; added to KEV on 7 March 2022 (Confirmed [75]).

2016 CVEs in this record and their KEV status

CVE	What	NVD published (or bulletin date)	CWE (NVD)	KEV added	Known ransomware use in KEV	Sources
CVE-2016-0800	DROWN, SSLv2	2016-03-01	CWE-200, CWE-310	not in KEV	no	[66][65]
CVE-2016-1019	Adobe Flash Player	2016-04-07	not checked	listed (date not checked)	yes	[73][65]
CVE-2016-2118	Badlock, Samba	2016-04-12	CWE-254	not in KEV	no	[67][65]
CVE-2016-3714	ImageTragick	2016-05-05	CWE-20	2024-09-09	not flagged	[68][65]
CVE-2016-0189	IE JScript and VBScript engines	2016-05-10 (MS16-051)	CWE-787	listed (date not checked)	yes	[46][65][109]
CVE-2016-4117	Adobe Flash Player	2016-05-11	not checked	listed (date not checked)	yes	[74][65]
CVE-2016-4655, -4656, -4657	Trident, iOS kernel and WebKit	2016-08-25 (iOS 9.3.5; NVD for -4657)	CWE-787 (-4657)	2022-05-24	not flagged	[41][69][65]
CVE-2016-6366	Cisco ASA SNMP	2016-08-18	CWE-120 (Cisco: CWE-119)	2022-05-24	not flagged	[48][47][65]
CVE-2016-6367	Cisco ASA CLI	not checked	not checked	2022-05-24	not flagged	[65]
CVE-2016-7855	Adobe Flash use-after-free	2016-11-01	CWE-416	2022-03-03	not flagged	[71][65]
CVE-2016-5195	Dirty COW	2016-11-10	CWE-362	2022-03-03	not flagged	[70][65]
CVE-2016-7255	Win32k elevation of privilege	2016-11-10	not checked	2021-11-03	yes	[72][45][65]
CVE-2016-9079	Firefox SVG animation use-after-free	2016-11-30 (MFSA 2016-92)	not checked	not checked	not checked	[76]
CVE-2016-6277	NETGEAR routers	2016-12-14	CWE-352	2022-03-07	not flagged	[75]

"Not flagged" means the CVE is not among the ten CVE-2016 entries KEV marks for known ransomware campaign use: CVE-2016-0034, -0099, -0151, -0167, -0189, -1019, -3309, -3351, -4117 and -7255 (Confirmed [65]).

The year in retrospect

The 2026.11.10 KEV catalog lists 60 CVE-2016 entries. None was added in 2016, because the catalog began in 2021: 10 were added on 3 November 2021, 40 in 2022, 5 in 2023, 2 in 2024, 2 in 2025 and 1 in 2026 (Struts CVE-2016-3081, added 8 October 2026). Microsoft accounts for 20 of them and Adobe for 7 (Inferred, counted from the catalog file [65]). A defender in 2016 had the vendor's "exploited" flag and the advisories; the catalog arrived five years later.

Part 6: supply chain, cloud and data breaches

Supply chain

- **Linux Mint, 20 February.** Attackers backdoored the Linux Mint 17.3 Cinnamon ISO and pointed the website's download links at it; people who downloaded that edition that day were affected (Confirmed [90]).
- **Transmission, March and August.** KeRanger in the 2.90 installers (Reported [53]) and OSX/Keydnap in a trojanized 2.92, signed with a different Developer ID and served from the official site on 28 and 29 August (Reported [91]). The same project's download channel was used twice in six months.
- **left-pad, 22 March.** A maintainer unpublished kik and 272 other packages; installs failed across dependency chains for about 2.5 hours, npm republished left-pad 0.0.3 and said it would make unpublishing harder (Confirmed [92]). This was an availability failure, not an intrusion, but it showed how deep transitive dependencies ran; the later attacks on the same registry are in the npm supply-chain study.

Data breaches disclosed in 2016

Organization	What the primary source says	Theft dated	Disclosed	Grade	Sources
LinkedIn	Email and hashed password data for more than 100 million members released; passwords unchanged since 2012 invalidated (completed 23 May); no new breach	2012	2016-05-18	Confirmed	[78]
Dropbox	A list of 68 million credentials (email with hashed and salted passwords) is real; passwords unchanged since mid-2012 reset; no improper account access seen	2012 (likely)	2016-08-25	Confirmed	[79]
Yahoo	Data on at least 500 million accounts stolen by what Yahoo believes is a state-sponsored actor; most passwords bcrypt-hashed, some records with security questions	Late 2014	2016-09-22	Confirmed	[80]
Yahoo	Data on more than one billion accounts stolen, passwords hashed in MD5; separately, proprietary code accessed to learn how to forge cookies, some of it tied to the same state-sponsored actor	2013-08	2016-12-14	Confirmed	[81]
Yahoo	After the October 2017 update, all accounts that existed at the time of the August 2013 theft were likely affected	2013-08	2017-10	Confirmed	[82]
Uber	About 57 million users' names, emails and phone numbers and about 600,000 US driver's license numbers on a third-party cloud service; not disclosed to individuals or regulators in 2016	Late 2016	2017-11-21	Confirmed	[84]
Panama Papers	11.5 million records from an offshore law firm, published with Suddeutsche Zeitung and more than 100 news organizations	not stated	2016-04-03	Reported	[87]

The SEC found in 2018 that Yahoo's security team learned of the December 2014 intrusion within days but the company did not disclose it until 2016, while selling its operating business to Verizon; Altaba paid $35 million (Confirmed [83]).

Cloud: the Uber key

The FTC's account of Uber is the year's clearest cloud lesson. In fall 2016 intruders used an access key an Uber engineer had posted on a code-sharing site to reach consumer data in third-party cloud storage, taking more than 25 million names and email addresses, 22 million phone numbers and 600,000 driver's license numbers. Uber paid them $100,000 through its bug bounty program and did not disclose the breach until November 2017 (Confirmed [85]). The secret in source code, the cloud storage it opened, and the decision to treat a breach as a bounty are three separate failures in one event (Inferred).

Regulators and older breaches

- **ASUS** settled FTC charges on 23 February over insecure routers and its AiCloud and AiDisk services after attackers reached more than 12,900 consumers' storage devices in February 2014; the order requires 20 years of independent audits (Confirmed [86]).
- **Dwolla** drew the CFPB's first data security action on 2 March, with a $100,000 penalty (Confirmed [89]).
- **Morgan Stanley Smith Barney** paid $1 million on 8 June after an employee copied data on about 730,000 accounts to a personal server from 2011 to 2014; the data was later posted online (Confirmed [88]).
- **OPM.** The House Oversight staff report of 7 September found the 2015 breach preventable, found that leadership ignored the Inspector General, found the 2014 breaches likely connected to the 2015 breach, and said OPM misled the public and Congress (Confirmed [95]).

Part 7: the government record

Date	Body	Action	Subject	Sources
2016-02-09	The White House	Cybersecurity National Action Plan	Commission, Federal CISO, IT Modernization Fund proposal	[93]
2016-02-23	FTC	Settlement	ASUS routers and cloud services	[86]
2016-03-02	CFPB	First data security action	Dwolla	[89]
2016-03-23	DOJ	Guilty plea	Su Bin	[34]
2016-03-24	DOJ	Indictment unsealed	Seven Iranians (DDoS, Bowman Dam)	[31]
2016-04-14	European Parliament	Final approval	EU data protection reform; fines up to 4 percent of worldwide turnover	[99]
2016-04-27	EU	Regulation (EU) 2016/679	GDPR; in force 24 May 2016, applicable 25 May 2018	[100]
2016-06-08	SEC	$1 million penalty	Morgan Stanley Smith Barney (Regulation S-P)	[88]
2016-07-06	EU	Directive (EU) 2016/1148	NIS Directive; transposition by 9 May 2018	[101]
2016-07-09	NATO	Warsaw Summit Communique	Cyberspace as a domain of operations (para. 70); Cyber Defence Pledge (para. 71)	[103]
2016-07-12	European Commission	Adoption	EU-U.S. Privacy Shield	[102]
2016-07-26	The White House	PPD-41	Threat response (DOJ, FBI, NCIJTF), asset response (DHS, NCCIC), intelligence support (ODNI, CTIIC); the Cyber Unified Coordination Group	[94]
2016-09-07	House Oversight and Government Reform	Staff report	The OPM breach	[95]
2016-09-13	NYDFS	Proposed regulation	Security program, CISO, third-party controls, annual certification for regulated financial institutions; State Register 28 Sep	[96]
2016-10-07	DHS and ODNI	Joint statement	Russian-directed email compromises; election-system scanning not attributed	[3]
2016-11-01	UK Government	National Cyber Security Strategy 2016 to 2021	GBP 1.9 billion over five years; a new National Cyber Security Centre	[104]
2016-11-07	National People's Congress, China	Cybersecurity Law	Multi-level protection (Art. 21), critical information infrastructure (Art. 31), data localization (Art. 37); effective 1 June 2017	[106]
2016-11-29	UK Parliament	Investigatory Powers Act 2016	Interception (Part 2), equipment interference (Part 5), bulk warrants and datasets (Parts 6 and 7)	[105]
2016-12-01	Commission on Enhancing National Cybersecurity	Final report	Six imperatives, 16 recommendations, 53 action items	[97]

Date	Body	Action	Subject	Sources
2016-12	FDA	Final guidance	Postmarket management of cybersecurity in medical devices	[98]
2016-12-29	The White House	Sanctions and expulsions	GRU, FSB, four GRU officers (Korobov, Gizunov, Kostyukov, Alexseyev), three companies (Special Technology Center, Zorsecurity or Esage Lab, ANO PO KSI); 35 officials given 72 hours to leave; two compounds closed from noon on 30 December	[11][12]
2016-12-29	Treasury OFAC	Designations under amended EO 13694	Evgeniy Bogachev, Aleksey Belan	[13]
2016-12-29	DHS and FBI	JAR-16-20296A	GRIZZLY STEPPE; first JAR attributing activity to a country	[1][2]
2018-04	SEC; FTC	Penalty; expanded settlement	Altaba (Yahoo), $35 million; Uber	[83][85]
2018-07-13	Grand jury, DOJ	Indictment	12 GRU officers (Units 26165 and 74455)	[5][6]
2018-09-06	DOJ; OFAC	Complaint; designation under EO 13722	Park Jin Hyok and KEJV	[29]
2018-10-01	FCA	Final Notice	Tesco Bank, GBP 16.4 million	[60][61]
2018-10-04	DOJ	Indictment	Seven GRU officers, anti-doping operations	[15]
2019-09-13	Treasury OFAC	Designations	Lazarus Group, Bluenoroff, Andariel	[27]
2020-10-15	Grand jury, DOJ	Indictment	Six GRU Unit 74455 officers, including the Ukraine attacks	[23]

Part 8: the defender view

Credentials were the front door. Most of the intrusions in this record that the sources describe in technical detail turn on a credential (Inferred, from Confirmed records [1][5][63][32][58][27][85]): a phished webmail password (APT28), a stolen DCCC login, factory-default IoT passwords (Mirai), hardcoded domain admin credentials (Shamoon 2), brute-forced RDP passwords (SamSam), stolen SWIFT credentials (Bangladesh Bank) and an access key in public code (Uber). The library's D3FEND pairings for the relevant techniques include Change Default Password, Multi-factor Authentication, Credential Rotation and Domain Account Monitoring (Part 9).

The JAR's useful half was the mitigation list. Its Top Seven Mitigation Strategies (patching, application allowlisting, restricting administrative privileges, network segmentation, input validation, file reputation and firewalls), which DHS says can prevent "as many as 85 percent of targeted cyber-attacks", and its advice on SPF records, user verification, EMET, AppLocker and web-shell and SQL-injection hardening, apply well beyond the election case (Confirmed [1]). Its indicator appendix shipped as CSV and STIX files with one YARA rule, and the JAR itself warned that much traffic from the listed IPs might be legitimate (Confirmed [1]). The CISA alert page that announced it names no actors and lists no controls; it points to the report (Confirmed [2]).

Control systems needed their own controls. TA17-163A's list for CrashOverride is the most specific defender guidance tied to a 2016 event: application allowlisting; authentication and authorization for ICS commands; ICS firewalls that inspect commands; MFA and least privilege; separate corporate and control credentials; patching, isolation, data diodes, segmentation and secure remote access; monitoring; and gold-image backups. Its detection guidance covers behavioral precursor analysis, monitoring at ICS boundaries, and login and account-administration analysis (Confirmed [19]).

Ransomware playbooks were written from the server side. AA18-337A's SamSam controls are auditing or disabling RDP, putting port 3389 behind a VPN, strong passwords with lockout, two-factor authentication, patching, backups, keeping RDP logs for at least 90 days, and restricting software installation (Confirmed [58]). SFMTA's response (switch off what customers touch, restore from backup, do not pay) shows the backup control working in a public agency (Confirmed [52]).

IoT defense was mostly procurement. TA16-288A's advice to change default passwords, disable UPnP and buy from vendors with strong security records puts most of the burden on buyers and makers, not on network defenders (Confirmed [63]). For a target like KrebsOnSecurity, the defense was an upstream provider with enough capacity (Confirmed [62]).

One D3FEND row is not a wiper defense. The library binds a single D3FEND countermeasure, Disk Partitioning, to T1561.002 Disk Structure Wipe. The controls that would have limited Shamoon 2, domain admin credential hygiene and offline backups, are not captured by that row (Inferred [107][32]).

The same controls recur. Read together, the JAR, TA16-288A, TA17-163A and AA18-337A repeat one list: credential hygiene, MFA, segmentation, application allowlisting, patching, and offline tested backups (Inferred [1][63][19][58]).

Part 9: MITRE mappings

Every id below was checked against the library's data files (`data/attack/technique_profiles.jsonl`, `data/attack/ics/technique_profiles.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl`, `technique_to_d3fend.jsonl`, `data/weaknesses/cwe.jsonl`, `data/weaknesses/capec.jsonl`) and the generated pages under `mitre/` on 11 November 2026 [107], with the objects that carry 2016 procedures opened on attack.mitre.org [9][10][17][20][21][22][28][33][36][42][59][108]. Names and tactics are those of ATT&CK v20.0; the live site showed content v20.1 on the C0025 page [20]. The Basis column says how strong each tie is: **Listed** means the cited source or ATT&CK object prints the technique id; **Described** means the source describes the behavior and the mapping is this study's; **Reported** means only a secondary source supports the behavior; **Inferred** marks a mapping no source states.

Left out on purpose: the exfiltration of DCCC and DNC documents over X-Tunnel's encrypted channels, because no source opened prints a technique id and the channel detail is not enough to choose one [5]; the 2015 Ukraine firmware corruption and UPS disconnects, because the C0028 technique rows were not checked for this study; the Sandworm study carries that record [16][17]; and the Trident chain, which is a Mobile matter outside the Enterprise and ICS tables [42].

ATT&CK Enterprise techniques

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1598	Phishing for Information	reconnaissance	Listed	ATT&CK maps Phishing for Information to APT28, whose 2016 Clinton campaign, DNC and DCCC compromises it records as reported	[9]
T1598.003	Spearphishing Link	reconnaissance	Listed	Spring 2016: APT28 email leads recipients to change passwords on a fake webmail domain (JAR); ATT&CK maps the sub-technique to APT28	[1][9]
T1583.001	Domains	resource-development	Described	APT28 lookalike domains and shortened URLs (JAR, 29 Dec 2016)	[1]
T1566	Phishing	initial-access	Described	Spear phishing to obtain the IOC-created ADAMS account (WADA, 13 Sep 2016); spear phishing in the Bangladesh Bank conspiracy (DOJ, mapping Inferred)	[14][29]
T1566.001	Spearphishing Attachment	initial-access	Described	TeleBots macro-laden Excel attachments against Ukraine's financial sector, second half of 2016; Locky spam with malicious Office documents (TA16-091A, 31 Mar 2016)	[24][49]
T1566.002	Spearphishing Link	initial-access	Described	APT29 malicious-link emails to over 1,000 recipients, summer 2015, recorded in the 29 Dec 2016 JAR; spear phishing of the Clinton campaign chairman, 19 Mar 2016 (indictment allegation)	[1][5]
T1078	Valid Accounts	stealth, persistence, privilege-escalation, initial-access	Listed	Stolen webmail credentials (JAR); a DCCC employee's stolen credentials used on 12 Apr 2016 (indictment allegation); ATT&CK maps Valid Accounts to APT28	[1][5][9]
T1078.001	Default Accounts	stealth, persistence, privilege-escalation, initial-access	Described	Mirai logs into IoT devices with 62 default username and password pairs (TA16-288A, 14 Oct 2016)	[63]
T1078.002	Domain Accounts	stealth, persistence, privilege-escalation, initial-access	Listed	Shamoon 2 spread with hardcoded stolen domain admin credentials (Unit 42, 30 Nov 2016); S0140 lists the sub-technique	[32][33]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1078.004	Cloud Accounts	stealth, persistence, privilege-escalation, initial-access	Described	Fall 2016: an access key an Uber engineer posted on a code-sharing site opens consumer data in third-party cloud storage (FTC)	[85]
T1199	Trusted Relationship	initial-access	Listed	ATT&CK G0007: access to the DCCC used to reach the DNC (indictment dates the DNC step to 18 Apr 2016)	[9][5]
T1190	Exploit Public-Facing Application	initial-access	Described	SamSam actors exploit JBoss in early 2016 (AA18-337A); Samas through vulnerable web servers (TA16-091A); SAP Invoker Servlet exploitation at 36 or more organizations (TA16-132A, 11 May 2016)	[58][49][77]
T1133	External Remote Services	persistence, initial-access	Described	SamSam actors use RDP with brute-forced or stolen credentials from mid-2016 (AA18-337A)	[58]
T1189	Drive-by Compromise	initial-access	Described	Dropping Elephant watering holes (Kaspersky, 8 Jul 2016)	[37]
T1195.002	Compromise Software Supply Chain	initial-access	Described	Backdoored Linux Mint 17.3 Cinnamon ISO on the download page, 20 Feb 2016; trojanized Transmission installers in March and August 2016 (vendor research, Reported)	[90][53][91]
T1203	Exploitation for Client Execution	execution	Described	STRONTIUM Flash zero-day CVE-2016-7855 (Microsoft, 1 Nov 2016); Firefox SVG use-after-free exploit in the wild (MFSA 2016-92, 30 Nov 2016); IE scripting engine CVE-2016-0189 exploited (MS16-051); PROMETHIUM and NEODYMIUM with CVE-2016-4117 in May 2016 (mapping Inferred)	[43][71][76][46][38]
T1059.001	PowerShell	execution	Listed	C0025, December 2016 Ukraine attack	[20]
T1059.003	Windows Command Shell	execution	Listed	C0025; SamSam (S0370)	[20][59]
T1059.005	Visual Basic	execution	Listed	C0025	[20]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1047	Windows Management Instrumentation	execution	Listed	C0025	[20]
T1569.002	Service Execution	execution	Described	Shamoon 2 executes copies on remote hosts as a service (Unit 42)	[32]
T1053.005	Scheduled Task	execution, persistence, privilege-escalation	Described	Shamoon 2 executes copies on remote hosts by scheduled task (Unit 42)	[32]
T1098	Account Manipulation	persistence, privilege-escalation	Listed	C0025	[20]
T1136	Create Account	persistence	Listed	C0025	[20]
T1136.002	Domain Account	persistence	Listed	C0025	[20]
T1543.003	Windows Service	persistence, privilege-escalation	Listed	C0025; the Bangladesh Bank malware registers itself as a service (BAE, 25 Apr 2016; mapping Inferred)	[20][26]
T1554	Compromise Host Software Binary	persistence	Listed	C0025	[20]
T1505.001	SQL Stored Procedures	persistence	Listed	C0025	[20]
T1068	Exploitation for Privilege Escalation	privilege-escalation	Described	Dirty COW CVE-2016-5195 exploited in the wild in October 2016 (NVD); Win32k CVE-2016-7255 exploited (MS16-135, 8 Nov 2016); STRONTIUM's Windows kernel zero-day per Microsoft, 1 Nov 2016 (CVE tie Inferred)	[70][43][45]
T1036.005	Match Legitimate Resource Name or Location	stealth	Listed	C0025	[20]
T1036.008	Masquerade File Type	stealth	Listed	C0025	[20]
T1036.010	Masquerade Account Name	stealth	Listed	C0025	[20]
T1027	Obfuscated Files or Information	stealth	Listed	C0025	[20]
T1027.002	Software Packing	stealth	Listed	C0025	[20]
T1685	Disable or Modify Tools	defense-impairment	Listed	C0025	[20]
T1685.001	Disable or Modify Windows Event Log	defense-impairment	Listed	C0025	[20]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1070.006	Timestomp	stealth	Listed	S0140 Shamoon, which ATT&CK records as observed in 2016 as Shamoon 2	[33]
T1553.002	Code Signing	defense-impairment	Reported	KeRanger installers signed with a valid Apple developer certificate (Unit 42, 4 Mar 2016); Keydnap signed with a different Developer ID (ESET, Aug 2016)	[53][91]
T1110	Brute Force	credential-access	Listed	C0025; SamSam brute-forced RDP credentials (AA18-337A)	[20][58]
T1110.001	Password Guessing	credential-access	Described	Mirai's default-credential logins (TA16-288A)	[63]
T1003.001	LSASS Memory	credential-access	Listed	C0025	[20]
T1056.001	Keylogging	collection, credential-access	Described	X-Agent keylogging turned on in the DCCC network, April 2016 (indictment allegation)	[5]
T1606.001	Web Cookies	credential-access	Described	An intruder used proprietary Yahoo code to learn how to forge cookies, tied in part to the state-sponsored actor (Yahoo 8-K, 14 Dec 2016)	[81]
T1018	Remote System Discovery	discovery	Listed	C0025	[20]
T1021.002	SMB/Windows Admin Shares	lateral-movement	Listed	C0025; Shamoon 2 remote copying (Unit 42; S0140 lists it)	[20][32][33]
T1021.001	Remote Desktop Protocol	lateral-movement	Described	SamSam over RDP from mid-2016 (AA18-337A)	[58]
T1570	Lateral Tool Transfer	lateral-movement	Listed	C0025; Shamoon 2 (S0140)	[20][32][33]
T1113	Screen Capture	collection	Described	X-Agent screenshot function turned on, April 2016 (indictment allegation)	[5]
T1119	Automated Collection	collection	Listed	ATT&CK G0007 for the 2016 intrusions	[9]
T1560	Archive Collected Data	collection	Listed	ATT&CK G0007; compressed DNC data sent to a GRU-leased computer in Illinois (indictment allegation)	[9][5]
T1530	Data from Cloud Storage	collection	Described	Uber consumer data taken from third-party cloud storage, fall 2016 (FTC)	[85]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1485	Data Destruction	impact	Listed	Shamoon 2 wipe set for 17 Nov 2016 (Unit 42); S0140 and S0604 list Data Destruction	[32][33][21]
T1486	Data Encrypted for Impact	impact	Listed	SamSam (AA18-337A; S0370 lists it); Locky and Samas (TA16-091A); SFMTA office computers, 25 Nov 2016	[58][59][49][52]
T1489	Service Stop	impact	Listed	S0604 Industroyer	[21]
T1498	Network Denial of Service	impact	Listed	Mirai against KrebsOnSecurity (20 Sep 2016) and OVH (late Sep 2016); ATT&CK G0007 maps the 2016 DDoS against WADA	[63][62][9]
T1498.001	Direct Network Flood	impact	Described	The 620 Gbps attack on KrebsOnSecurity used no amplification or reflection (victim's own post); TA16-288A volumes	[62][63]
T1499.004	Application or System Exploitation	impact	Listed	S0604 Industroyer (the Siemens relay denial of service)	[21]
T1529	System Shutdown/Reboot	impact	Listed	Shamoon 2 forces a reboot after wiping (Unit 42); S0140 lists it	[32][33]
T1561.002	Disk Structure Wipe	impact	Listed	Shamoon 2 overwrites the MBR and partition tables (Unit 42; S0140); KillDisk corrupted master boot records in the 2015 Ukraine attack (IR-ALERT-H-16-056-01)	[32][33][16]
T1565.001	Stored Data Manipulation	impact	Listed	ATT&CK G0082: DYEPACK altering SWIFT transaction records (APT38; the group page names the 2016 Bank of Bangladesh heist without a date per technique)	[28]
T1565.002	Transmitted Data Manipulation	impact	Listed	ATT&CK G0082: SWIFT messages altered on the way to a printer	[28]
T1565.003	Runtime Data Manipulation	impact	Listed	ATT&CK G0082: DYEPACK.FOX removing traces	[28]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1657	Financial Theft	impact	Described	Bangladesh Bank, February 2016 ($81 million, DOJ); Tesco Bank, 5 to 7 Nov 2016 (GBP 2.26 million, FCA)	[26][29][60]

ATT&CK for ICS techniques

The ATT&CK record of the December 2016 Kyiv attack is split across two objects. Campaign C0025 maps the operator tradecraft; the grid-impact techniques sit on the Industroyer software page, S0604, last modified 12 May 2026 (Confirmed [20][21]). A layer built from C0025 alone would understate the impact (Inferred [20][21]). The library has no generated ICS technique pages, so these ids link to attack.mitre.org; each was checked in `data/attack/ics/technique_profiles.jsonl`, with names matching the live pages [107].

Id	Name (ATT&CK for ICS v20.0)	Tactic(s)	Basis	Where it appears	Sources
T1701.001	PowerShell	execution	Listed	C0025	[20]
T1701.002	Windows Command Shell	execution	Listed	C0025	[20]
T1701.004	Visual Basic	execution	Listed	C0025	[20]
T0867	Lateral Tool Transfer	lateral-movement	Listed	C0025	[20]
T0849	Masquerading	evasion	Listed	C0025	[20]
T0886	Remote Services	initial-access, lateral-movement	Listed	C0025	[20]
T0859	Valid Accounts	persistence, lateral-movement	Listed	C0025	[20]
T0800	Activate Firmware Update Mode	inhibit-response-function	Listed	S0604 Industroyer	[21]
T0806	Brute Force I/O	impair-process-control	Listed	S0604; rapid breaker toggling described in TA17-163A	[21][19]
T0809	Data Destruction	inhibit-response-function	Listed	S0604 (its wiper)	[21][19]
T0813	Denial of Control	impact	Listed	S0604	[21]
T0814	Denial of Service	inhibit-response-function	Listed	S0604, via CVE-2015-5374 against SIPROTEC relays; TA17-163A notes the relay needs a manual reset	[21][25][19]
T0815	Denial of View	impact	Listed	S0604	[21]
T0816	Device Restart/Shutdown	inhibit-response-function	Listed	S0604	[21]
T0827	Loss of Control	impact	Listed	S0604	[21]
T0829	Loss of View	impact	Listed	S0604	[21]

Id	Name (ATT&CK for ICS v20.0)	Tactic(s)	Basis	Where it appears	Sources
T0831	Manipulation of Control	impact	Listed	S0604 (opening breakers); direct commands to RTUs in TA17-163A	[21][19]
T0832	Manipulation of View	impact	Listed	S0604	[21]
T0837	Loss of Protection	impact	Listed	S0604	[21]
T0846	Remote System Discovery	discovery	Listed	S0604; network mapping over OPC in TA17-163A	[21][19]
T0881	Service Stop	inhibit-response-function	Listed	S0604	[21]
T0888	Remote System Information Discovery	discovery	Listed	S0604	[21]

TA17-163A describes the same capability in advisory terms: valid commands sent directly to RTUs, including rapid breaker toggling; denial of service against serial COM ports; network mapping over OPC; a Siemens relay denial of service that needs a manual reset; and a wiper (Confirmed [19]). NVD lists CWE-19 for CVE-2015-5374, the Siemens EN100 flaw behind T0814; CWE-19 is a category the library's `cwe.jsonl` does not carry, so the CWE table leaves it out (Confirmed [25][107]).

ATT&CK groups, software and campaigns

Groups (every page exists under `/mitre/groups/`):

Id	Group (library name)	The 2016 tie	Grade	Sources
G0007	APT28	Spring 2016 political party intrusion; DNC, DCCC and Clinton campaign (ATT&CK "reportedly"); WADA ADAMS access and DDoS; STRONTIUM zero-days	Confirmed	[1][9][14][43]
G0016	APT29	Summer 2015 political party intrusion recorded in 2016; post-election spear phishing (Volexity, "believes")	Confirmed	[1][10][8]
G0034	Sandworm Team (aliases include Telebots, ELECTRUM)	C0028 and C0025; TeleBots financial-sector attacks	Confirmed	[17][20][22][24]
G0032	Lazarus Group	Bangladesh Bank (DOJ allegation; Treasury designation)	Confirmed	[29][27]
G0082	APT38 (aliases include Bluenoroff, BeagleBoyz)	ATT&CK lists the 2016 Bank of Bangladesh heist	Confirmed	[28][27]
G0138	Andariel	September 2016 South Korean defense intrusion, relayed by Treasury	Reported	[27]
G0041	Strider (alias ProjectSauron)	Kaspersky, 8 Aug 2016	Confirmed	[35][36]
G0040	Patchwork (alias Dropping Elephant)	Kaspersky, 8 Jul 2016	Confirmed	[37]
G0056	PROMETHIUM	CVE-2016-4117, May 2016	Confirmed	[38]

Id	Group (library name)	The 2016 tie	Grade	Sources
G0055	NEODYMIUM	CVE-2016-4117, May 2016	Confirmed	[38]
G0010	Turla	RUAG report names Turla-family malware (group mapping Inferred)	Inferred	[39]
G0020	Equation	The Shadow Brokers' claim about their material's origin, as Cisco relays it	Confirmed (as a claim)	[47]

Not mapped, because no source opened supports a group object: the Shamoon 2 operator (the pages opened do not tie it to APT33, G0064), the Mirai operators, the NSO Group customer behind the Mansoor messages, ITSecTeam and Mersad, Su Bin's co-conspirators, the Lurk group, the Avalanche operators, the Tesco Bank attackers, and the Uber and Yahoo intruders [33][107].

Software (pages exist under `/mitre/software/` except where noted):

Id	Software	The 2016 tie	Sources
S0604	Industroyer (alias CRASHOVERRIDE)	17 Dec 2016 Kyiv attack	[18][19][21]
S0089	BlackEnergy	Found in the 2015 Ukraine networks, role unknown in 2016	[16][17]
S0607	KillDisk	2015 Ukraine wiping; TeleBots 2016	[16][17][24][108]
S0140	Shamoon (alias Disttrack)	Shamoon 2, 17 Nov 2016	[32][33]
S0023	CHOPSTICK (alias X-Agent)	DCCC and DNC keylogging and screenshots (indictment); named by CrowdStrike and the JAR	[5][7][108]
S0117	XTunnel (alias X-Tunnel)	Document exfiltration from the DCCC and DNC (indictment)	[5][7][108]
S0137	CORESHELL	Named in the JAR	[1][107]
S0046	CozyCar	Named in the JAR	[1][107]
S0037	HAMMERTOSS	Named in the JAR	[1][107]
S0139	PowerDuke	Post-election spear phishing, Nov 2016	[8][108]
S0370	SamSam (alias Samas)	Early 2016 onward	[49][58][59]
S0289	Pegasus for iOS (Mobile; no library page)	Trident, Aug 2016	[40][42]

Not linked, because ATT&CK has no software object by that name in the library data: Mirai, Bashlite and Gafgyt, Locky, KeRanger, Keydnap, the Bangladesh Bank malware as BAE describes it, ProjectSauron's platform, and Lurk [107].

Campaigns (pages exist under `/mitre/campaigns/`):

Id	Campaign	Window in library data	Sources
C0028	2015 Ukraine Electric Power Attack (Sandworm Team; BlackEnergy, KillDisk)	2015-12 to 2016-01	[17][107]
C0025	2016 Ukraine Electric Power Attack (Sandworm Team; Industroyer)	2016-12	[20][107]

The library's `campaigns.jsonl` has no campaign object for the 2016 political party and election intrusions, the Bangladesh Bank theft, Shamoon 2 or Mirai, so those bind to groups, software and techniques only (Confirmed [107]).

CWE and CAPEC

The CWE ids are those NVD lists for each CVE, except the two Mirai rows, which are this study's bindings (Inferred) (Confirmed [66][67][68][69][70][71][75][48][109]). The CAPEC column lists the attack patterns the library's `data/weaknesses/cwe.jsonl` relates to that CWE, linked where a generated page exists; choosing the closest pattern is this study's reading (Inferred [107]).

CWE	Weakness (library name)	CVEs or events from the 2016 record	CAPEC the library relates
CWE-362	Concurrent Execution using Shared Resource with Improper Synchronization	CVE-2016-5195 Dirty COW	CAPEC-26 (race conditions) and CAPEC-29 (time-of-check and time-of-use race conditions) (binding Inferred)
CWE-120	Buffer Copy without Checking Size of Input	CVE-2016-6366 (Cisco labels it CWE-119)	CAPEC-100 Overflow Buffers (the library also relates CAPEC-10, 14, 24, 42 and others)
CWE-20	Improper Input Validation	CVE-2016-3714 ImageTragick	broad class; no single pattern chosen
CWE-352	Cross-Site Request Forgery	CVE-2016-6277 NETGEAR	CAPEC-62 Cross Site Request Forgery (the library also relates CAPEC-111, 462 and 467)
CWE-200	Exposure of Sensitive Information to an Unauthorized Actor	CVE-2016-0800 DROWN	broad class; no single pattern chosen
CWE-787	Out-of-bounds Write	CVE-2016-4657, CVE-2016-0189	none in library data
CWE-416	Use After Free	CVE-2016-7855	none in library data
CWE-798	Use of Hard-coded Credentials	Mirai's default credentials (TA16-288A; binding Inferred, the alert states no CWE)	CAPEC-70 Try Common or Default Usernames and Passwords, which the library links to T1078.001 and CWE-798
CWE-1392	Use of Default Credentials	Mirai (binding Inferred; the alert does not state a CWE)	none in library data

Left out: CWE-310 (DROWN) and CWE-254 (Badlock), which NVD lists but the library's `cwe.jsonl` does not carry, and CWE-19 for CVE-2015-5374, a category the library does not carry (Confirmed [66][67][25][107]).

ATT&CK itself relates CAPEC entries to several techniques in the Enterprise table, as the library's technique profiles record them: CAPEC-163 Spear Phishing for T1566.001 and T1566.002, CAPEC-98 Phishing for T1566 and T1598, CAPEC-560 Use of Known Domain Credentials for T1078, CAPEC-49 Password Brute Forcing for T1110.001, CAPEC-112 Brute Force for T1110, CAPEC-125 Flooding and CAPEC-482 TCP Flood for T1498.001, CAPEC-555 Remote Services with Stolen Credentials for T1133, CAPEC-186 Malicious Software Update for T1195.002, and CAPEC-206 Signing Malicious Code for T1553.002 [107].

D3FEND countermeasures

Pairings come from `data/attack/technique_to_d3fend.jsonl`; every page exists under `/mitre/d3fend/` [107]. Only pairings the record gives a reason to apply are listed.

Technique from the record	D3FEND countermeasures the library maps	Why it applies in 2016
T1078.001 Default Accounts	Change Default Password, Account Locking, Agent Authentication	Mirai; TA16-288A's first mitigation [63]
T1110.001 Password Guessing	Multi-factor Authentication, Credential Hardening, Change Default Password	Mirai logins; SamSam brute force [63][58]
T1498.001 Direct Network Flood	Inbound Traffic Filtering, Inbound Session Volume Analysis, Network Traffic Filtering	KrebsOnSecurity and OVH [62][63]
T1566.001, T1566.002 Spearphishing	Email Filtering, URL Analysis (T1566.002 only), Content Quarantine, Email Removal	APT29 and APT28 campaigns; TeleBots; Locky [1][24][49]
T1078.002 Domain Accounts	Domain Account Monitoring, User Account Permissions, Account Locking	Shamoon 2's stolen domain admin credentials [32]
T1561.002 Disk Structure Wipe	Disk Partitioning (the only pairing)	Shamoon 2 and KillDisk; see Part 8 on why one row is not enough [32][16]
T1486 Data Encrypted for Impact	Restore File, File Integrity Monitoring, Decoy File, Local File Permissions	SamSam, Locky, SFMTA's restore from backup [58][49][52]
T1021.001 Remote Desktop Protocol	Remote Terminal Session Detection, Session Termination	SamSam from mid-2016 [58]
T1190 Exploit Public-Facing Application	Inbound Traffic Filtering, Network Traffic Signature Analysis, Process Segment Execution Prevention	SamSam's JBoss entry; SAP Invoker Servlet [58][77]
T1195.002 Compromise Software Supply Chain	Software Inventory, Software Update, Restore Software, Asset Vulnerability Enumeration	Linux Mint ISO; Transmission installers [90][53][91]
T1606.001 Web Cookies	Credential Revocation, Reissue Credential, Authentication Cache Invalidation	Yahoo forged cookies [81]
T1068 Exploitation for Privilege Escalation	Segment Address Offset Randomization, Process Segment Execution Prevention, Stack Frame Canary Validation	Win32k CVE-2016-7255; these memory-safety hardenings do not address a race condition such as Dirty COW, where the fix is the kernel update (Inferred) [45][70]

Technique from the record	D3FEND countermeasures the library maps	Why it applies in 2016
T1003.001 LSASS Memory	Process Spawn Analysis, Process Lineage Analysis, Hardware-based Process Isolation	C0025 credential dumping [20]

The library data has no D3FEND mapping for T1598.003 Spearphishing Link (reconnaissance), T1485 Data Destruction, T1021.002 SMB/Windows Admin Shares, T1553.002 Code Signing or T1059.005 Visual Basic; none is invented here [107].

Navigator layers

The study's techniques are saved as two ATT&CK Navigator layers pinned to ATT&CK v20: the Enterprise layer navigator/library-layers/chronicle-2016.json (63 techniques, 81 technique-tactic entries) and the ICS layer navigator/case-studies/chronicle-2016-ics.json (22 techniques), both listed on the Navigator layers page. Scores show the basis, not severity: 100 where the source or ATT&CK object prints the id, 70 where the source describes the behavior and this study assigns the id, 50 where only a Reported source supports it, and 40 for an Inferred mapping. Each entry's comment names the source numbers in the Sources table below, and each technique is shown under every tactic it has in v20.0.

Cross-cutting themes

Hack and leak became an instrument of state policy. The DCCC and DNC intrusions, the WADA exemption files and the Guccifer 2.0 and DCLeaks releases all paired theft with publication (Confirmed [3][5][14][15]). The response came as sanctions and expulsions announced the same day as a technical report (Confirmed [11][1]); reading that as the template for later years is this study's view (Inferred).

Trust in the message, not the sender. The New York Fed said the Bangladesh Bank instructions were fully authenticated by SWIFT under standard protocols (Confirmed [30]); that they passed because they came from the bank's own compromised system is this study's reading (Inferred); Transmission's installers were signed with real Apple developer identities (Reported [53][91]); Linux Mint's download page served its own users the backdoored ISO (Confirmed [90]). In each case the channel was genuine and the sender was compromised (Inferred).

Old thefts, new disclosures. LinkedIn (2012), Dropbox (2012), Yahoo (2013 and 2014) and OPM (2015) all surfaced or were investigated in 2016, and Uber's 2016 theft surfaced in 2017 (Confirmed [78][79][80][81][95][84]). The year's account totals describe disclosure, not intrusion.

Destructive tooling matured on both sides of the IT and OT line. KillDisk and Shamoon 2 destroyed data in 2016 (Confirmed [24][32]), and ESET judged it highly probable that Industroyer cut power in Kyiv (Confirmed [18]); the industrial incidents in the ICS study for 2024 to 2026 show the same pairing of IT access and OT effect (Inferred).

The rulebook was written in one year. GDPR, the NIS Directive, PPD-41, the NYDFS proposal, the UK strategy and Investigatory Powers Act, China's Cybersecurity Law, NATO's domain declaration and the FDA's postmarket guidance all date to 2016 (Confirmed [100][101][94][96][104][105][103][98]; China Reported [106]). Whether the year's incidents caused them is not something the sources state.

What is overstated and what is understated

This section is the study's reading of the record (Inferred).

- **Overstated: "Russia hacked the election systems".** DHS and ODNI declined in October 2016 to attribute the state-system scanning [3]; the indictment alleges one state board website breach of about 500,000 voter records [5]; the ICA says Russian intelligence "accessed elements of" electoral boards [4]. None of the sources opened says vote tallies were altered.
- **Overstated: "Mirai took down the internet".** The only opened account of Dyn is press relaying Flashpoint, which did not rule out other botnets [64]; the US-CERT alert on Mirai does not mention Dyn [63].
- **Overstated: the "$951 million" Bangladesh heist.** That was the attempted amount (BAE); $81 million was lost, and Treasury gives $851 million attempted [26][27][29].
- **Overstated: Shamoon 2 and Industroyer as attributed state operations in 2016.** Unit 42 named no actor [32]; ESET said "highly probable" and named no state [18]; the US attribution of the Ukraine attacks came in the 2020 indictment and the 2021 CISA updates [23][19].
- **Overstated: the JAR's indicators.** The appendix was the most actionable part and the least specific; the JAR itself warned the IP list mixed malicious and legitimate traffic [1].
- **Overstated: "2016 KEV additions".** KEV did not exist in 2016; every 2016 CVE in it was added from 2021 onward [65].
- **Understated: the start date of the election intrusions.** The JAR and the ICA place Russian intelligence in political networks from summer 2015, not June 2016 [1][4].
- **Understated: the government record names a party, not the party.** The JAR names the victim only as "a U.S. political party"; the DNC and DCCC names in ATT&CK G0007 carry MITRE's own "reportedly" [1][9].
- **Understated: the tradecraft inside the account counts.** Yahoo's forged cookies and Uber's posted cloud key are the transferable lessons, not the totals [81][85].
- **Understated: Ukraine's impact in the ATT&CK record.** C0025 alone omits the grid-impact techniques that sit on S0604 [20][21].
- **Understated: commodity IoT.** Mirai drove the largest attack volumes of the year but has no ATT&CK software object [63][107].
- **Understated: ransomware volume.** The IC3's 2,673 complaints are self-reported, and the FBI says most victims do not report [50][51].

Discrepancies in the record

- **Bangladesh Bank amounts.** BAE: $951 million attempted, $81 million unaccounted for; DOJ: $81 million stolen; Treasury: about $80 million stolen, $851 million attempted. All three are given with their sources [26][29][27].
- **The executive order number.** The White House fact sheet writes "Executive Order 13964"; Treasury names EO 13694, which this study treats as correct (transposition Inferred) [12][13]. The number of the amending order (EO 13757) was not confirmed because the Federal Register page did not open [13].

- **Uber's counts.** Uber's statement gives about 57 million users and about 600,000 driver's licenses; the FTC gives more than 25 million names and emails, 22 million phone numbers and 600,000 licenses [84][85].
- **The CWE for CVE-2016-6366.** Cisco labels it CWE-119; NVD lists CWE-120 [47][48].
- **The Iran indictment.** DOJ unsealed it on 24 March 2016 [31]; the Iran-attributed actors study dates the indictment itself to 21 January 2016 from the FBI record.
- **Industroyer's grade by source.** ESET's research is graded Confirmed here as the vendor's own analysis, with its "highly probable" kept; the attribution to a state rests only on the later US records [18][19][23].
- **The 2015 alert's date.** The CISA page shows only its 2021 revision; the release date of 25 February 2016 is Inferred from the alert number [16].
- **CrowdStrike's URL.** The original 14 June 2016 post address now leads to a page that quotes it; the quoted text is what was read [7].
- **ATT&CK versions.** The live site showed content v20.1 on the C0025 page; the library and this study's names and tactics are v20.0 [20][107].
- **The library's own 2016 entries.** NOTABLE_INCIDENTS.md gives a "1.2+ Tbps DDoS against Dyn", names three individuals for Mirai and says the DNC hack had a "measurable effect" on the election. No source opened for this study supports the Dyn figure or the effect claim, and the Mirai attributions were not checked [107][63][64].

Sources

All sources were opened on 11 November 2026. Grade is the source's evidence grade as used in this study. Addresses shown as code rather than as links refuse automated link checkers (the sec.gov filings and press releases, the FTC releases, the NYDFS release and Uber's statement); copy them into a browser to open them.

#	Source	URL	Opened	Grade
1	DHS and FBI, Joint Analysis Report JAR-16-20296A, GRIZZLY STEPPE: Russian Malicious Cyber Activity, 29 Dec 2016 (PDF)	https://www.cisa.gov/sites/default/files/publications/JAR_16-20296A_GRIZZLY%20STEPPE-2016-1229.pdf	2026-11-11	Confirmed
2	CISA (US-CERT), alert GRIZZLY STEPPE: Russian Malicious Cyber Activity, 29 Dec 2016, revised 30 Dec 2016	https://www.cisa.gov/news-events/alerts/2016/12/29/grizzly-steppe-russian-malicious-cyber-activity	2026-11-11	Confirmed
3	DHS, Joint statement from DHS and ODNI on election security, 7 Oct 2016 (also served at the dhs.gov/archive path)	https://www.dhs.gov/news/2016/10/07/joint-statement-department-homeland-security-and-office-director-national	2026-11-11	Confirmed
4	ODNI, ICA 2017-01D, Assessing Russian Activities and Intentions in Recent US Elections, 6 Jan 2017 (Internet Archive copy of the dni.gov PDF)	https://web.archive.org/web/20171231151527id_/https://www.dni.gov/files/documents/ICA_2017_01.pdf	2026-11-11	Confirmed
5	United States v. Netyksho et al., indictment, D.D.C., 13 Jul 2018 (Internet Archive copy of the justice.gov file)	https://web.archive.org/web/20191231204014id_/https://www.justice.gov/file/1080281/download	2026-11-11	Confirmed (allegations)

#	Source	URL	Opened	Grade
6	DOJ, Grand jury indicts 12 Russian intelligence officers for hacking offenses related to the 2016 election, 13 Jul 2018 (Internet Archive copy)	https://web.archive.org/web/20181231141024id_/https://www.justice.gov/opa/pr/grand-jury-indicts-12-russian-intelligence-officers-hacking-offenses-related-2016-election	2026-11-11	Confirmed (allegations)
7	CrowdStrike, DNC investigation page quoting "Bears in the Midst: Intrusion into the Democratic National Committee" of 14 Jun 2016 (the original crowdstrike.com/blog/ address leads here)	https://www.crowdstrike.com/en-us/blog/bears-midst-intrusion-democratic-national-committee/	2026-11-11	Confirmed (FBI alert point Reported)
8	Volexity, PowerDuke: post-election spear-phishing campaigns targeting think tanks and NGOs, 9 Nov 2016	https://www.volexity.com/blog/2016/11/09/powerduke-post-election-spear-phishing-campaigns-targeting-think-tanks-and-ngos/	2026-11-11	Confirmed
9	MITRE ATT&CK, group G0007 APT28	https://attack.mitre.org/groups/G0007/	2026-11-11	Confirmed
10	MITRE ATT&CK, group G0016 APT29	https://attack.mitre.org/groups/G0016/	2026-11-11	Confirmed
11	The White House (archived), Statement by the President on actions in response to Russian malicious cyber activity and harassment, 29 Dec 2016	https://obamawhitehouse.archives.gov/the-press-office/2016/12/29/statement-president-actions-response-russian-malicious-cyber-activity	2026-11-11	Confirmed
12	The White House (archived), Fact sheet: actions in response to Russian malicious cyber activity and harassment, 29 Dec 2016	https://obamawhitehouse.archives.gov/the-press-office/2016/12/29/fact-sheet-actions-response-russian-malicious-cyber-activity-and	2026-11-11	Confirmed
13	US Treasury, press release jl0693, designations under amended EO 13694, 29 Dec 2016	https://home.treasury.gov/news/press-releases/jl0693	2026-11-11	Confirmed
14	WADA, WADA confirms attack by Russian cyber espionage group, 13 Sep 2016	https://www.wada-ama.org/en/news/wada-confirms-attack-russian-cyber-espionage-group	2026-11-11	Confirmed
15	DOJ, US charges Russian GRU officers with international hacking and related influence and disinformation operations, 4 Oct 2018 (Internet Archive copy)	https://web.archive.org/web/20211223235640id_/https://www.justice.gov/opa/pr/us-charges-russian-gru-officers-international-hacking-and-related-influence-and	2026-11-11	Confirmed (allegations)
16	CISA (ICS-CERT), IR-ALERT-H-16-056-01, Cyber-attack against Ukrainian critical infrastructure (released 2016, revised 20 Jul 2021)	https://www.cisa.gov/news-events/ics-alerts/ir-alert-h-16-056-01	2026-11-11	Confirmed
17	MITRE ATT&CK, campaign C0028, 2015 Ukraine Electric Power Attack	https://attack.mitre.org/campaigns/C0028/	2026-11-11	Confirmed
18	ESET WeLiveSecurity, Industroyer: biggest threat to industrial control systems since Stuxnet, 12 Jun 2017	https://www.welivesecurity.com/2017/06/12/industroyer-biggest-threat-industrial-control-systems-since-stuxnet/	2026-11-11	Confirmed
19	CISA (US-CERT), TA17-163A, CrashOverride malware, 12 Jun 2017, revised 20 Jul 2021	https://www.cisa.gov/news-events/alerts/2017/06/12/crashoverride-malware	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
20	MITRE ATT&CK, campaign C0025, 2016 Ukraine Electric Power Attack	https://attack.mitre.org/campaigns/C0025/	2026-11-11	Confirmed
21	MITRE ATT&CK, software S0604 Industroyer	https://attack.mitre.org/software/S0604/	2026-11-11	Confirmed
22	MITRE ATT&CK, group G0034 Sandworm Team	https://attack.mitre.org/groups/G0034/	2026-11-11	Confirmed
23	DOJ, Six Russian GRU officers charged in connection with worldwide deployment of destructive malware, 19 Oct 2020 (Internet Archive copy)	https://web.archive.org/web/20220115133724id_/https://www.justice.gov/opa/pr/six-russian-gru-officers-charged-connection-worldwide-deployment-destructive-malware-and	2026-11-11	Confirmed (allegations)
24	ESET WeLiveSecurity, The rise of TeleBots: analyzing disruptive KillDisk attacks, 13 Dec 2016	https://www.welivesecurity.com/2016/12/13/rise-telebots-analyzing-disruptive-killdisk-attacks/	2026-11-11	Confirmed
25	NIST NVD, CVE-2015-5374 record (API 2.0)	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2015-5374	2026-11-11	Confirmed
26	BAE Systems Threat Research, Two bytes to $951m, 25 Apr 2016	https://baesystemsai.blogspot.com/2016/04/two-bytes-to-951m.html	2026-11-11	Confirmed
27	US Treasury, press release sm774, sanctions on North Korean state-sponsored groups (Lazarus Group, Bluenoroff, Andariel), 13 Sep 2019	https://home.treasury.gov/news/press-releases/sm774	2026-11-11	Confirmed (Andariel 2016 point Reported)
28	MITRE ATT&CK, group G0082 APT38	https://attack.mitre.org/groups/G0082/	2026-11-11	Confirmed
29	DOJ, North Korean regime-backed programmer charged with conspiracy to conduct multiple cyber attacks and intrusions, 6 Sep 2018 (Internet Archive copy)	https://web.archive.org/web/20220107083011id_/https://www.justice.gov/opa/pr/north-korean-regime-backed-programmer-charged-conspiracy-conduct-multiple-cyber-attacks-and	2026-11-11	Confirmed (allegations)
30	Federal Reserve Bank of New York, statement on the Bangladesh Bank payments, 9 Mar 2016	https://www.newyorkfed.org/newsevents/statements/2016/0311-2016	2026-11-11	Confirmed
31	DOJ, Seven Iranians working for IRGC-affiliated entities charged, 24 Mar 2016 (Internet Archive copy)	https://web.archive.org/web/20211221220725id_/https://www.justice.gov/opa/pr/seven-iranians-working-islamic-revolutionary-guard-corps-affiliated-entities-charged	2026-11-11	Confirmed (allegations)
32	Palo Alto Networks Unit 42, Shamoon 2: return of the Disttrack wiper, 30 Nov 2016	https://unit42.paloaltonetworks.com/unit42-shamoon-2-return-disttrack-wiper/	2026-11-11	Confirmed
33	MITRE ATT&CK, software S0140 Shamoon	https://attack.mitre.org/software/S0140/	2026-11-11	Confirmed
34	DOJ, Chinese national pleads guilty to conspiring to hack into US defense contractors' systems, 23 Mar 2016 (Internet Archive copy)	https://web.archive.org/web/20210110124502id_/https://www.justice.gov/opa/pr/chinese-national-pleads-guilty-conspiring-hack-us-defense-contractors-systems-steal-sensitive	2026-11-11	Confirmed
35	Kaspersky GReAT (Securelist), FAQ: the ProjectSauron APT, 8 Aug 2016	https://securelist.com/faq-the-projectsauron-apt/75533/	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
36	MITRE ATT&CK, group G0041 Strider	https://attack.mitre.org/groups/G0041/	2026-11-11	Confirmed
37	Kaspersky GReAT (Securelist), The Dropping Elephant actor, 8 Jul 2016	https://securelist.com/the-dropping-elephant-actor/75328/	2026-11-11	Confirmed
38	Microsoft Security Blog, Twin zero-day attacks: PROMETHIUM and NEODYMIUM target individuals in Europe, 14 Dec 2016	https://www.microsoft.com/en-us/security/blog/2016/12/14/twin-zero-day-attacks-promethium-and-neodymium-target-individuals-in-europe/	2026-11-11	Confirmed
39	Swiss GovCERT, Technical report about the RUAG espionage case, 23 May 2016 (GovCERT's website repository)	https://github.com/govcert-ch/website/blob/main/content/blog/technical-report-about-the-ruag-espionage-case/post.html	2026-11-11	Confirmed
40	Citizen Lab, The Million Dollar Dissident: NSO Group's iPhone zero-days used against a UAE human rights defender, 24 Aug 2016	https://citizenlab.ca/2016/08/million-dollar-dissident-iphone-zero-day-nso-group-uae/	2026-11-11	Confirmed
41	Apple, About the security content of iOS 9.3.5, 25 Aug 2016	https://support.apple.com/en-us/HT207107	2026-11-11	Confirmed
42	MITRE ATT&CK, software S0289 Pegasus for iOS (Mobile)	https://attack.mitre.org/software/S0289/	2026-11-11	Confirmed
43	Microsoft Security Blog, Our commitment to our customers' security (STRONTIUM), 1 Nov 2016	https://www.microsoft.com/en-us/security/blog/2016/11/01/our-commitment-to-our-customers-security/	2026-11-11	Confirmed
44	Google Online Security Blog, Disclosing vulnerabilities to protect users, 31 Oct 2016 (date only read; the body is script-rendered)	https://security.googleblog.com/2016/10/disclosing-vulnerabilities-to-protect.html	2026-11-11	Confirmed (date only)
45	Microsoft, Security Bulletin MS16-135, 8 Nov 2016	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2016/ms16-135	2026-11-11	Confirmed
46	Microsoft, Security Bulletin MS16-051, 10 May 2016	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2016/ms16-051	2026-11-11	Confirmed
47	Cisco, Security Advisory cisco-sa-20160817-asa-snmp, Cisco ASA SNMP remote code execution, 17 Aug 2016	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-20160817-asa-snmp	2026-11-11	Confirmed
48	NIST NVD, CVE-2016-6366 record (API 2.0)	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2016-6366	2026-11-11	Confirmed
49	CISA (US-CERT), TA16-091A, Ransomware and recent variants, 31 Mar 2016, revised 29 Sep 2016	https://www.cisa.gov/news-events/alerts/2016/03/31/ransomware-and-recent-variants	2026-11-11	Confirmed
50	FBI IC3, PSA I-091516-PSA, Ransomware victims urged to report infections, 15 Sep 2016	https://www.ic3.gov/PSA/2016/PSA160915	2026-11-11	Confirmed
51	FBI IC3, 2016 Internet Crime Report (PDF)	https://www.ic3.gov/AnnualReport/Reports/2016_IC3Report.pdf	2026-11-11	Confirmed
52	SFMTA, Update: SFMTA ransomware attack, Nov 2016	https://www.sfmta.com/blog/update-sfmta-ransomware-attack	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
53	Palo Alto Networks Unit 42, New OS X ransomware KeRanger infected Transmission BitTorrent client installer, Mar 2016	https://unit42.paloaltonetworks.com/new-os-x-ransomware-keranger-infected-transmission-bittorrent-client-installer/	2026-11-11	Reported
54	Kaspersky, press release: No More Ransom, law enforcement and IT security companies join forces to fight ransomware, 25 Jul 2016	https://usa.kaspersky.com/about/press-releases/2016_no-more-ransom-law-enforcement-and-it-security-companies-join-forces-to-fight-ransomware	2026-11-11	Confirmed
55	No More Ransom, About the project	https://www.nomoreransom.org/en/about-the-project.html	2026-11-11	Confirmed
56	Kaspersky GReAT (Securelist), The hunt for Lurk, 2016	https://securelist.com/the-hunt-for-lurk/75944/	2026-11-11	Reported
57	CISA (US-CERT), TA16-336A, Avalanche (crimeware-as-a-service infrastructure), 1 Dec 2016	https://www.cisa.gov/news-events/alerts/2016/12/01/avalanche-crimeware-service-infrastructure	2026-11-11	Confirmed
58	CISA and FBI, AA18-337A, SamSam ransomware, 3 Dec 2018	https://www.cisa.gov/news-events/cybersecurity-advisories/aa18-337a	2026-11-11	Confirmed
59	MITRE ATT&CK, software S0370 SamSam	https://attack.mitre.org/software/S0370/	2026-11-11	Confirmed
60	UK FCA, Final Notice to Tesco Personal Finance plc (Tesco Bank), 1 Oct 2018 (PDF)	https://www.fca.org.uk/publication/final-notices/tesco-personal-finance-plc-2018.pdf	2026-11-11	Confirmed
61	UK FCA, FCA fines Tesco Bank for failures in 2016 cyber attack, Oct 2018	https://www.fca.org.uk/news/press-releases/fca-fines-tesco-bank-failures-2016-cyber-attack	2026-11-11	Confirmed
62	KrebsOnSecurity, KrebsOnSecurity hit with record DDoS, 21 Sep 2016 (the victim's own account)	https://krebsonsecurity.com/2016/09/krebsonsecurity-hit-with-record-ddos/	2026-11-11	Confirmed
63	CISA (US-CERT), TA16-288A, Heightened DDoS threat posed by Mirai and other botnets, 14 Oct 2016, revised to 2017	https://www.cisa.gov/news-events/alerts/2016/10/14/heightened-ddos-threat-posed-mirai-and-other-botnets	2026-11-11	Confirmed
64	KrebsOnSecurity, Hacked cameras, DVRs powered today's massive internet outage, 21 Oct 2016	https://krebsonsecurity.com/2016/10/hacked-cameras-dvrs-powered-todays-massive-internet-outage/	2026-11-11	Reported
65	CISA, Known Exploited Vulnerabilities catalog, JSON feed (catalog version 2026.11.10)	https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed (counts Inferred)
66	NIST NVD, CVE-2016-0800 record (API 2.0)	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2016-0800	2026-11-11	Confirmed
67	NIST NVD, CVE-2016-2118 record (API 2.0)	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2016-2118	2026-11-11	Confirmed
68	NIST NVD, CVE-2016-3714	https://nvd.nist.gov/vuln/detail/CVE-2016-3714	2026-11-11	Confirmed
69	NIST NVD, CVE-2016-4657 record (API 2.0)	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2016-4657	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
70	NIST NVD, CVE-2016-5195 record (API 2.0; the detail page is nvd.nist.gov/vuln/detail/CVE-2016-5195)	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2016-5195	2026-11-11	Confirmed
71	NIST NVD, CVE-2016-7855	https://nvd.nist.gov/vuln/detail/CVE-2016-7855	2026-11-11	Confirmed
72	NIST NVD, CVE-2016-7255 record (API 2.0)	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2016-7255	2026-11-11	Confirmed
73	NIST NVD, CVE-2016-1019	https://nvd.nist.gov/vuln/detail/CVE-2016-1019	2026-11-11	Confirmed
74	NIST NVD, CVE-2016-4117	https://nvd.nist.gov/vuln/detail/CVE-2016-4117	2026-11-11	Confirmed
75	NIST NVD, CVE-2016-6277	https://nvd.nist.gov/vuln/detail/CVE-2016-6277	2026-11-11	Confirmed
76	Mozilla, MFSA 2016-92, Firefox SVG animation remote code execution, 30 Nov 2016	https://www.mozilla.org/en-US/security/advisories/mfsa2016-92/	2026-11-11	Confirmed
77	CISA (US-CERT), TA16-132A, Exploitation of SAP business applications, 11 May 2016	https://www.cisa.gov/news-events/alerts/2016/05/11/exploitation-sap-business-applications	2026-11-11	Confirmed
78	LinkedIn, Protecting our members, 18 May 2016	https://www.linkedin.com/blog/member/trust-and-safety/protecting-our-members	2026-11-11	Confirmed
79	Dropbox, Resetting passwords to keep your files safe, 25 Aug 2016, updated 31 Aug 2016	https://blog.dropbox.com/topics/company/resetting-passwords-to-keep-your-files-safe	2026-11-11	Confirmed
80	Yahoo, Form 8-K exhibit 99.1, 22 Sep 2016 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/1011006/000119312516717056/d260014dex991.htm`	2026-11-11	Confirmed
81	Yahoo, Form 8-K exhibit 99.1, 14 Dec 2016 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/1011006/000119312516793106/d305610dex991.htm`	2026-11-11	Confirmed
82	Yahoo Help, account security issues (the 2013 theft, updated October 2017)	https://help.yahoo.com/kb/account/SLN28451.html	2026-11-11	Confirmed
83	SEC, press release 2018-71, Altaba (formerly Yahoo) charged with failing to disclose massive cybersecurity breach, 24 Apr 2018	`https://www.sec.gov/news/press-release/2018-71`	2026-11-11	Confirmed
84	Uber Newsroom, 2016 data security incident, 21 Nov 2017	`https://www.uber.com/newsroom/2016-data-incident/`	2026-11-11	Confirmed
85	FTC, Uber agrees to expanded settlement with FTC related to privacy, security claims, Apr 2018	`https://www.ftc.gov/news-events/news/press-releases/2018/04/uber-agrees-expanded-settlement-ftc-related-privacy-security-claims`	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
86	FTC, ASUS settles FTC charges that insecure home routers and cloud services put consumers' privacy at risk, 23 Feb 2016	`https://www.ftc.gov/news-events/news/press-releases/2016/02/asus-settles-ftc-charges-insecure-home-routers-cloud-services-put-consumers-privacy-risk`	2026-11-11	Confirmed
87	ICIJ, Giant leak of offshore financial records exposes global array of crime and corruption (Panama Papers overview), 3 Apr 2016	https://www.icij.org/investigations/panama-papers/20160403-panama-papers-global-overview/	2026-11-11	Reported
88	SEC, press release 2016-112, Morgan Stanley failed to safeguard customer data, 8 Jun 2016	`https://www.sec.gov/news/pressrelease/2016-112.html`	2026-11-11	Confirmed
89	CFPB, CFPB takes action against Dwolla for misrepresenting data security practices, 2 Mar 2016	https://www.consumerfinance.gov/about-us/newsroom/cfpb-takes-action-against-dwolla-for-misrepresenting-data-security-practices/	2026-11-11	Confirmed
90	Linux Mint blog, Beware of hacked ISOs if you downloaded Linux Mint on February 20th, 2016	https://blog.linuxmint.com/?p=2994	2026-11-11	Confirmed
91	ESET WeLiveSecurity, OSX/Keydnap spreads via signed Transmission application, 30 Aug 2016	https://www.welivesecurity.com/2016/08/30/osxkeydnap-spreads-via-signed-transmission-application/	2026-11-11	Reported
92	npm blog, kik, left-pad, and npm, Mar 2016	https://blog.npmjs.org/post/141577284765/kik-left-pad-and-npm	2026-11-11	Confirmed
93	The White House (archived), Fact sheet: Cybersecurity National Action Plan, 9 Feb 2016	https://obamawhitehouse.archives.gov/the-press-office/2016/02/09/fact-sheet-cybersecurity-national-action-plan	2026-11-11	Confirmed
94	The White House (archived), Presidential Policy Directive 41, United States Cyber Incident Coordination, 26 Jul 2016	https://obamawhitehouse.archives.gov/the-press-office/2016/07/26/presidential-policy-directive-united-states-cyber-incident	2026-11-11	Confirmed
95	House Committee on Oversight and Government Reform, The OPM data breach: how the government jeopardized our national security for more than a generation, 7 Sep 2016	https://oversight.house.gov/report/opm-data-breach-government-jeopardized-national-security-generation/	2026-11-11	Confirmed
96	NYDFS, press release on the proposed first-in-the-nation cybersecurity regulation, 13 Sep 2016	`https://www.dfs.ny.gov/reports_and_publications/press_releases/pr1609131`	2026-11-11	Confirmed
97	Commission on Enhancing National Cybersecurity, Report on securing and growing the digital economy, 1 Dec 2016 (NIST PDF)	https://www.nist.gov/system/files/documents/2016/12/02/cybersecurity-commission-report-final-post.pdf	2026-11-11	Confirmed
98	FDA, Postmarket management of cybersecurity in medical devices, final guidance, Dec 2016	https://www.fda.gov/regulatory-information/search-fda-guidance-documents/postmarket-management-cybersecurity-medical-devices	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
99	European Parliament, Data protection reform: Parliament approves new rules fit for the digital era, 14 Apr 2016	https://www.europarl.europa.eu/news/en/press-room/20160407IPR21776/data-protection-reform-parliament-approves-new-rules-fit-for-the-digital-era	2026-11-11	Confirmed
100	Publications Office of the EU, Regulation (EU) 2016/679 (GDPR), CELEX 32016R0679 metadata	https://publications.europa.eu/resource/celex/32016R0679	2026-11-11	Confirmed
101	Publications Office of the EU, Directive (EU) 2016/1148 (NIS), CELEX 32016L1148 metadata	https://publications.europa.eu/resource/celex/32016L1148	2026-11-11	Confirmed
102	European Commission, IP/16/2461, EU-U.S. Privacy Shield adopted, 12 Jul 2016	https://ec.europa.eu/commission/presscorner/api/documents?reference=IP/16/2461&language=en	2026-11-11	Confirmed
103	NATO, Warsaw Summit Communique, 9 Jul 2016	https://www.nato.int/cps/en/natohq/official_texts_133169.htm	2026-11-11	Confirmed
104	UK Government, National Cyber Security Strategy 2016 to 2021, 1 Nov 2016 (PDF)	https://assets.publishing.service.gov.uk/media/5a81914de5274a2e8ab54ae9/national_cyber_security_strategy_2016.pdf	2026-11-11	Confirmed
105	legislation.gov.uk, Investigatory Powers Act 2016 (c. 25)	https://www.legislation.gov.uk/ukpga/2016/25/contents	2026-11-11	Confirmed
106	DigiChina (Stanford), translation of the Cybersecurity Law of the People's Republic of China	https://digichina.stanford.edu/work/translation-cybersecurity-law-of-the-peoples-republic-of-china-effective-june-1-2017/	2026-11-11	Reported
107	TeamStarWolf library, main branch: `data/attack/` (campaigns, groups, software, technique profiles, ICS technique profiles, technique_to_d3fend), `data/weaknesses/` (cwe, capec), the `mitre/` tree and NOTABLE_INCIDENTS.md	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/data	2026-11-11	Confirmed
108	MITRE ATT&CK, software S0607 KillDisk, S0023 CHOPSTICK, S0117 XTunnel and S0139 PowerDuke	https://attack.mitre.org/software/S0607/ (and the same path for each id)	2026-11-11	Confirmed
109	NIST NVD, CVE-2016-0189 record (API 2.0 returns CWE-787 as the NVD primary weakness; the detail page is nvd.nist.gov/vuln/detail/CVE-2016-0189)	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2016-0189	2026-11-11	Confirmed

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Notable Incidents, Threat Actors, Malware Families, CVE Reference
- CWE Reference, CAPEC Reference, D3FEND Reference
- Ransomware Defense, ICS and OT Security, ICS ATT&CK Atlas, Firmware and IoT Security, Cloud Attack Reference, Supply Chain Security
- Home studies: Sandworm; Russia-attributed actors; United States-attributed actors; Iran-attributed actors; Other state-linked actors; SolarWinds and SUNBURST; Stuxnet; npm supply-chain attacks; ICS attacks and advisories, 2024 to 2026
- Related studies: North Korea-attributed actors; The Hacker and the State cases; Fancy Bear Goes Phishing cases; The zero-day trade and its fallout; China-attributed actors
- Series: 2019, 2020, 2021
- Groups: G0007 APT28, G0016 APT29, G0034 Sandworm Team, G0032 Lazarus Group, G0082 APT38, G0138 Andariel, G0041 Strider, G0040 Patchwork, G0056 PROMETHIUM, G0055 NEODYMIUM, G0010 Turla, G0020 Equation
- Software: S0604 Industroyer, S0089 BlackEnergy, S0607 KillDisk, S0140 Shamoon, S0023 CHOPSTICK, S0117 XTunnel, S0137 CORESHELL, S0046 CozyCar, S0037 HAMMERTOSS, S0139 PowerDuke, S0370 SamSam
- Campaigns: C0025 2016 Ukraine Electric Power Attack, C0028 2015 Ukraine Electric Power Attack
- Techniques: T1566.002 Spearphishing Link, T1598.003 Spearphishing Link, T1078 Valid Accounts, T1078.001 Default Accounts, T1078.002 Domain Accounts, T1498 Network Denial of Service, T1561.002 Disk Structure Wipe, T1486 Data Encrypted for Impact, T1565.001 Stored Data Manipulation, T1195.002 Compromise Software Supply Chain
- CAPEC: CAPEC-70, CAPEC-163, CAPEC-125, CAPEC-26
- Navigator layers, including this study's layers, chronicle-2016.json and chronicle-2016-ics.json